

**BỘ GIÁO DỤC VÀ ĐÀO TẠO
TRƯỜNG ĐẠI HỌC NGOẠI THƯƠNG**



**BÁO CÁO TIỂU LUẬN VÀ THỰC HÀNH
MÔN HỌC
MẠNG MÁY TÍNH**

ĐỀ TÀI:

**PHÁT HIỆN BẤT THƯỜNG TRONG WEB
SERVER ACCESS LOG BẰNG MACHINE LEARNING
CƠ BẢN**

Sinh viên thực hiện	: Lê Phương Anh Phạm Khánh Chi Lê Ngọc Minh Đinh Đức Thiện Nguyễn Việt Hoàng
Giảng viên	: TS Ngô Hải Anh
Khoa	: Công nghệ và khoa học dữ liệu
Lớp	: COSH201 (2627 – HK1)GD1.1

Hà Nội – 2026

PHIẾU CHẤM ĐIỂM

Sinh viên thực hiện:

Họ và tên	Chữ ký	Ghi chú
Lê Phương Anh Phạm Khánh Chi Lê Ngọc Minh Đình Đức Thiện Nguyễn Việt Hoàng		

Giảng viên chấm:

Họ và tên	Điểm	Chữ ký
Ngô Hải Anh		

MỤC LỤC

MỤC LỤC	3
DANH MỤC CÁC KÝ HIỆU, TỪ VIẾT TẮT	5
DANH MỤC HÌNH ẢNH	6
DANH MỤC BẢNG	7
LỜI MỞ ĐẦU	8
CHƯƠNG 1: TỔNG QUAN VỀ ĐỀ TÀI BÁO CÁO	10
1.1. Bối cảnh thực tế và vấn đề mạng máy tính	10
1.2. Mục tiêu, câu hỏi nghiên cứu	11
1.2.1. Mục tiêu và Câu hỏi nghiên cứu	11
1.2.2. Phạm vi nghiên cứu	11
1.3. Phương pháp tổng quát	12
1.4. Kết quả dự kiến	12
1.5. Kết luận chương 1	13
CHƯƠNG 2: CƠ SỞ LÝ THUYẾT	14
2.1. Giao thức HTTP dưới góc độ chu kỳ Yêu cầu - Phản hồi	14
2.2. Định dạng log và hai hướng tiếp cận phát hiện bất thường	14
2.3. Cơ sở lý thuyết Isolation Forest	16
2.4. Nguyên tắc bất thường không đồng nghĩa với tấn công	17
2.5. Kết luận chương 2	17
CHƯƠNG 3: NGUỒN DỮ LIỆU VÀ PHƯƠNG PHÁP TRÍCH XUẤT ĐẶC TRƯNG	18
3.1. Nguồn dữ liệu và Phương pháp lấy mẫu	18
3.1.1. Giới thiệu bộ dữ liệu và tính phù hợp với bài toán mạng	18
3.1.2. Mô tả bộ dữ liệu sau khi trích xuất	18
3.1.3. Phương pháp lấy mẫu chuỗi thời gian liên tục cho bài toán mạng và giới hạn	20
3.2. Quá trình tiền xử lý dữ liệu	21
3.2.1. Bóc tách và ép kiểu dữ liệu	21
3.2.2. Xử lý giá trị khuyết thiếu dưới góc độ mạng	22
3.2.3. Chuẩn hóa đường dẫn tài nguyên URI theo hai cột	22
3.2.4. Cơ sở lý luận của việc bảo toàn dữ liệu trùng lặp và ngoại lai	23
3.2.5. Thống kê mô tả sau tiền xử lý	23
3.3. Phương pháp Trích xuất đặc trưng dưới góc độ Mạng	25
3.3.1. Đặc trưng cấp độ Request	25

3.3.2. Đặc trưng cấp độ Cửa sổ IP Window	26
3.4. Tinh chỉnh quy tắc phát hiện URI nghi ngờ (is_suspicious_uri) phát hiện quan trọng từ EDA (Exploratory Data Analysis)	27
3.5. Minh họa kết quả.	28
3.6. Hạn chế và lưu ý khi sử dụng đặc trưng	29
3.7. Kết luận chương 3	29
CHƯƠNG 4: XÂY DỰNG CHƯƠNG TRÌNH VÀ THỰC NGHIỆM MÔ HÌNH	31
4.1. Kiến trúc pipeline tổng thể	31
4.2. Mô hình Học không giám sát (Isolation Forest)	31
4.2.1. Đặt vấn đề & mục tiêu	31
4.2.2. Phương pháp xây dựng không gian đặc trưng	33
4.2.3. Cơ sở Lý thuyết & Thuật toán	34
4.2.4. Hoạt động của thuật toán	39
4.2.5. Kết quả	44
4.3. Kết luận chương 4	44
CHƯƠNG 5: KẾT QUẢ VÀ THẢO LUẬN	46
5.1. Phương pháp phân tích	46
5.2. Kết quả phân loại định lượng	47
5.3. Đánh giá độ tin cậy của bất thường	49
5.4. Phân tích False Positive	49
5.4.1. Tiêu chí xác định False Positive	49
5.4.2. Các nhóm được xác định là False Positive	50
5.4.3. Nguyên nhân gốc rễ	51
5.4.4. Đề xuất giảm thiểu False Positive	51
5.5. Phân tích sâu nhóm rủi ro cao: Dò quét/thăm dò	52
5.6. Phân tích nhóm chiếm tỷ trọng lớn: Bất thường payload/lỗi ứng dụng	53
5.7. Kết luận cho mô hình Isolation Forest	53
5.8. Kết luận chương 5	54
CHƯƠNG 6: KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN	56
TÀI LIỆU THAM KHẢO	58

DANH MỤC CÁC KÝ HIỆU, TỪ VIẾT TẮT

Từ viết tắt	Tiếng Anh	Tiếng Việt
HTTP	Transfer Protocol	Giao thức truyền tải siêu văn bản
HTTPS	HTTP Secure	Giao thức HTTP bảo mật
URI	Uniform Resource Identifier	Định danh tài nguyên thống nhất
IP	Internet Protocol	Giao thức Internet (địa chỉ mạng)
TCP/UDP	Transmission Control Protocol / User Datagram Protocol	Giao thức điều khiển truyền/Giao thức gói tin người dùng
DDoS	Distributed Denial of Service	Tấn công từ chối dịch vụ phân tán
SQLi	SQL Injection	Chèn mã truy vấn SQL
XSS	Cross-Site Scripting	Chèn mã kịch bản chéo trang
WAF	Web Application Firewall	Tường lửa ứng dụng Web
IDS/IPS	Intrusion Detection/Prevention System	Hệ thống phát hiện/ngăn chặn xâm nhập
ML	Machine Learning	Học máy
EDA	Exploratory Data Analysis	Phân tích khám phá dữ liệu
CART	Classification And Regression Trees	Cây phân loại và hồi quy
CSV	Comma-Separated Values	Tập giá trị phân tách bằng dấu phẩy
TP/FP/TN/FN	True/False Positive/Negative	Dương/Âm tính thật/giả

DANH MỤC HÌNH ẢNH

Hình 3.1. Phân bố mã trạng thái HTTP trên 100.000 request (trục tung thang logarit).....	24
Hình 3.2. Tương quan giữa độ dài URL và dung lượng gói tin phản hồi giữa request bình thường (2xx/3xx) và bất thường (4xx/5xx).....	28
Hình 4.1. Kiến trúc quy trình tổng thể.....	31
Hình 4.2. Phân bố Anomaly Score.....	37
Hình 4.3. Phân bố không gian dữ liệu PCA (chuẩn hóa StandardScaler).....	39
Hình 4.4. Số lượng time-window bị gán Anomaly theo từng khung 15 phút.....	41
Hình 5.1. Phân bố số lượng time-window theo từng nhóm nguyên nhân.....	48
Hình 5.2. Phân bố lại mức độ rủi ro của 131 cảnh báo sau khi áp dụng phân tích domain.....	49

DANH MỤC BẢNG

Bảng 3.1. Data Dictionary của tập dữ liệu sau chuẩn hóa.....	19
Bảng 3.2. Thống kê dataset sau tiền xử lý.....	23
Bảng 3.3. Đặc trưng đầu vào của mô hình phát hiện bất thường.....	26
Bảng 4.1. So sánh giá trị trung bình đặc trưng giữa nhóm Normal và Anomaly.....	37
Bảng 4.2. Thống kê tổng quan kết quả phát hiện bất thường.....	40
Bảng 4.3. Top time-window có mức độ bất thường cao nhất theo Anomaly_Score.	41
Bảng 4.4. IP có tần suất xuất hiện lặp lại nhiều nhất trong danh sách bất thường...	42
Bảng 4.5. Phân loại sơ bộ nguyên nhân của các time-window bị gán Anomaly	42

LỜI MỞ ĐẦU

Cùng với sự phát triển của thương mại điện tử, khối lượng lưu lượng truy cập vào các hệ thống Web ngày càng lớn, kéo theo nguy cơ bị dò quét, khai thác lỗ hổng và tấn công từ chối dịch vụ ngày một gia tăng. Việc rà soát thủ công hàng trăm nghìn dòng nhật ký truy cập (access log) mỗi ngày để phát hiện dấu hiệu bất thường là điều bất khả thi đối với quản trị viên hệ thống.

Nhằm góp phần giải quyết bài toán trên, Báo cáo đã tìm hiểu và nghiên cứu về "*Phát hiện bất thường trong Web Server Access Log bằng Machine Learning cơ bản*". Mục tiêu của Báo cáo gồm các nội dung chính:

Chương 1. Giới thiệu: chương này trình bày bối cảnh, mục tiêu, câu hỏi nghiên cứu và phạm vi của đề tài.

Chương 2. Cơ sở lý thuyết: chương này trình bày các kiến thức Mạng máy tính liên quan trực tiếp đến đề tài (giao thức HTTP, mã trạng thái, phân biệt phát hiện theo signature và theo bất thường) và cơ sở lý thuyết các mô hình được sử dụng (Isolation Forest và Decision Tree).

Chương 3. Dataset và phương pháp: chương này mô tả nguồn dữ liệu, quy trình lấy mẫu, tiền xử lý và xây dựng đặc trưng mạng.

Chương 4. Xây dựng chương trình và thực nghiệm: chương này trình bày kiến trúc pipeline và các mô hình học máy được sử dụng.

Chương 5. Kết quả và thảo luận: chương này trình bày, so sánh kết quả các mô hình với baseline và phân tích dưới góc độ Mạng máy tính, bao gồm phân tích các trường hợp false positive.

Chương 6. Kết luận và hướng phát triển: chương này tổng hợp kết quả đạt được, trả lời câu hỏi nghiên cứu và đề xuất hướng phát triển.

Báo cáo đã đạt được một số kết quả khả quan trong việc xây dựng quy trình phát hiện bất thường trên dữ liệu Web log thực tế. Tuy nhiên, báo cáo

không thể tránh khỏi những thiếu sót, nhóm rất mong nhận được góp ý từ giảng viên để hoàn thiện hơn.

CHƯƠNG 1: TỔNG QUAN VỀ ĐỀ TÀI BÁO CÁO

1.1. Bối cảnh thực tế và vấn đề mạng máy tính

Trong kỷ nguyên số hóa, các hệ thống thương mại điện tử hoạt động trên nền tảng giao thức HTTP/HTTPS luôn phải tiếp nhận một khối lượng lưu lượng truy cập khổng lồ mỗi ngày. Mỗi tương tác của người dùng như xem sản phẩm hay tìm kiếm, đặt hàng đều để lại dấu vết dưới dạng một dòng nhật ký truy cập (access log) ghi nhận địa chỉ IP, thời điểm, phương thức HTTP, tài nguyên được yêu cầu, mã trạng thái phản hồi và dung lượng dữ liệu trao đổi. Song song với lưu lượng hợp lệ, các hệ thống Web công khai trên Internet cũng liên tục chịu các hình thức truy cập bất thường. Các hình thái truy cập bất thường điển hình thường xuyên xuất hiện trên Web Server bao gồm:

- Tấn công cạn kiệt tài nguyên: Gửi lượng lớn yêu cầu hợp lệ trong thời gian ngắn nhằm làm sập khả năng phản hồi của máy chủ.
- Cào dữ liệu quá mức: Các mạng botnet tự động vắt kiệt băng thông mạng để thu thập dữ liệu trái phép.
- Dò quét lỗ hổng và các thư mục ẩn: Trình sát mạng bằng cách liên tục truy vấn các thư mục ẩn hoặc nhồi nhét mã độc vào URI (SQL Injection và Cross-Site Scripting).

Vấn đề đặt ra: Đối với một hệ thống thương mại điện tử quy mô lớn, nhật ký truy cập (Web Server Access Logs) có thể sinh ra hàng triệu dòng mỗi giờ. Việc rà soát log thủ công để tìm kiếm dấu vết bất thường là điều hoàn toàn không khả thi. Do đó, hệ thống cần một phương pháp tự động để thiết lập đường cơ sở cho hành vi mạng bình thường, từ đó phân lập các luồng lưu lượng dị biệt một cách chính xác. Báo cáo này tiếp cận bài toán từ góc độ Mạng máy tính kết hợp Học máy: sử dụng các đặc trưng trích xuất từ giao thức HTTP (tần suất request, mã trạng thái, độ dài URL, dung lượng phản hồi...) làm đầu vào cho các mô hình học máy cơ bản, nhằm tự động khoanh

vùng các request và khung thời gian có khả năng bất thường cao, hỗ trợ quản trị viên ưu tiên điều tra thay vì rà soát toàn bộ log.

1.2. Mục tiêu, câu hỏi nghiên cứu

1.2.1. Mục tiêu và Câu hỏi nghiên cứu

Nghiên cứu được thực hiện nhằm mục tiêu cốt lõi là xây dựng một hệ thống tự động phát hiện độ lệch của lưu lượng mạng so với đường cơ sở, đồng thời trích xuất các quy tắc phòng thủ có thể triển khai thực tiễn.

Để đạt được mục tiêu này, báo cáo tập trung giải quyết câu hỏi nghiên cứu sau: “Liệu các đặc trưng hành vi mạng trích xuất từ nhật ký HTTP, kết hợp thuật toán học không giám sát (Isolation Forest), có phát hiện được ip_window bất thường hiệu quả hơn ngưỡng thống kê đơn giản hay không. Những bất thường phát hiện được phản ánh ý nghĩa gì dưới góc độ Mạng máy tính?”

Mục tiêu cụ thể:

- Xây dựng pipeline xử lý dữ liệu hoàn chỉnh, trích xuất đặc trưng ở cấp độ Request và Window.
- Huấn luyện mô hình Isolation Forest (không giám sát) để phát hiện được bất thường trong ip_window.
- Phân tích false positive có hệ thống (không dựa cảm tính), diễn giải kết quả dưới góc độ mạng, và trích xuất luật khả triển khai cho WAF/IDS.

1.2.2. Phạm vi nghiên cứu

Không gian dữ liệu: Báo cáo sử dụng bộ dữ liệu công khai "Web Server Access Logs" (tác giả Elias Dabbas, Kaggle), nội dung là nhật ký truy cập thực tế của trang thương mại điện tử Zambil (zambil.ir, Iran), công bố gốc bởi Zaker, Farzin (2019) trên Harvard Dataverse. Do file gốc có kích thước 3,5GB với hơn 10 triệu dòng, báo cáo trích xuất một mẫu liên tục 100.000 dòng đầu tiên (từ 22/01/2019, 03:56:14 đến 08:01:41 - khoảng 4 giờ 5 phút

của một buổi sáng) làm phạm vi thực nghiệm. Giới hạn của phạm vi lấy mẫu này được phân tích cụ thể ở Chương 3 và Chương 6.

Phân tầng mạng: Đóng khung nghiêm ngặt tại Tầng Ứng dụng (Layer 7). Nghiên cứu khai thác ngữ nghĩa của giao thức HTTP để đánh giá hành vi luồng lưu lượng.

1.3. Phương pháp tổng quát

Để trả lời câu hỏi nghiên cứu và giải quyết bài toán xử lý dữ liệu lớn trong nhật ký mạng, nhóm nghiên cứu áp dụng một luồng quy trình khép kín, kết hợp chặt chẽ giữa lý thuyết mạng và kỹ thuật Học máy cơ bản, bao gồm ba trụ cột chính:

- Trích xuất đặc trưng và gom cụm theo cửa sổ thời gian (1 phút) để bảo toàn bối cảnh luồng lưu lượng.
- Xây dựng mô hình dán nhãn minh bạch bằng 5 quy tắc minh bạch dựa trên ngưỡng phân vị, làm nhãn tham chiếu độc lập.
- Huấn luyện mô hình học không giám sát Isolation Forest (không dùng nhãn) qua đó cho ra kết quả đáng tin cậy và trích xuất luật phòng thủ tổng quan.

1.4. Kết quả dự kiến

Báo cáo dự kiến tạo ra: (1) Một pipeline tái lập được từ log thô tới kết quả phát hiện bất thường; (2) Mô hình học máy không giám sát dự đoán có tỷ lệ dự đoán chính xác các truy cập bất thường cao và có tính áp dụng cao trong thực tế; (3) Phân tích false positive định lượng, làm cơ sở đánh giá mức độ tin cậy trước khi cân nhắc triển khai thực tế.

1.5. Kết luận chương 1

Chương này đã trình bày bối cảnh của bài toán phát hiện bất thường trong Web log, mục tiêu, câu hỏi nghiên cứu và phạm vi dữ liệu sử dụng. Chương 2 tiếp theo sẽ trình bày cơ sở lý thuyết Mạng máy tính và Học máy liên quan trực tiếp đến đề tài.

CHƯƠNG 2: CƠ SỞ LÝ THUYẾT

2.1. Giao thức HTTP dưới góc độ chu kỳ Yêu cầu - Phản hồi

Mỗi dòng log trong dataset tương ứng với một yêu cầu HTTP - một thông điệp ở tầng ứng dụng, không nên đồng nhất với khái niệm "gói tin" ở tầng vận chuyển/mạng, vì một request có thể được truyền qua nhiều gói TCP hoặc nhiều request có thể dùng chung một kết nối TCP. Một request HTTP gồm phương thức, tài nguyên được yêu cầu (URI) và các header; phản hồi gồm mã trạng thái và nội dung.

Phương thức HTTP quan sát được trong dataset: GET (98.695 lượt), HEAD (725), POST (578), OPTIONS (2) - chỉ 4 trong số các phương thức phổ biến (GET, HEAD, POST, PUT, PATCH, DELETE, OPTIONS), phản ánh đúng đặc thù một website thương mại điện tử với hành vi xem sản phẩm (GET) áp đảo.

Mã trạng thái HTTP được chia thành 5 nhóm: 1xx (Thông tin), 2xx (Thành công), 3xx (Chuyển hướng), 4xx (Lỗi phía Client) và 5xx (Lỗi phía Server). Trong đó, nhóm 4xx cần phân biệt rõ 401 (thiếu hoặc sai thông tin xác thực) và 403 (đã xác thực nhưng bị từ chối truy cập) - hai mã có ý nghĩa an ninh khác nhau dù cùng thuộc nhóm lỗi Client. Tỷ lệ mã 4xx tăng bất thường là dấu hiệu điển hình của hành vi dò quét thư mục/tài nguyên không tồn tại; tỷ lệ mã 5xx tăng cao phản ánh backend gặp sự cố hoặc bị khai thác gây cạn kiệt tài nguyên.

Dung lượng phản hồi (bytes) đo lường mức tiêu thụ băng thông của mỗi request, liên hệ trực tiếp tới khái niệm goodput trong lý thuyết mạng - lượng dữ liệu hữu ích thực sự được truyền tới client.

2.2. Định dạng log và hai hướng tiếp cận phát hiện bất thường

Dữ liệu gốc tuân theo Nginx/Apache Combined Log Format - chuẩn ghi log phổ biến nhất trong hạ tầng máy chủ Web hiện nay, gồm các trường:

địa chỉ IP, thời điểm, dòng yêu cầu (request line), mã trạng thái và dung lượng phản hồi.

Nguyên lý nền tảng của giám sát an ninh mạng là xây dựng một baseline mô tả định lượng của hành vi bình thường trong một bối cảnh xác định (theo hệ thống, theo nhóm người dùng, theo khung giờ) - sau đó xác định độ lệch (deviation) của quan sát hiện tại so với baseline đó. Một điểm quan trọng là baseline luôn gắn với ngữ cảnh: cùng một khối lượng truy vấn có thể là bình thường với một endpoint phục vụ nội dung công khai nhưng lại là bất thường nghiêm trọng nếu xảy ra ở một endpoint đăng nhập hoặc thanh toán. Trên cơ sở đó, có hai hướng tiếp cận phát hiện hành vi bất thường: Signature-based detection (khớp mẫu đã biết trước - ví dụ chuỗi ký tự đặc trưng của SQL Injection hay XSS; ưu điểm dễ diễn giải, nhược điểm không phát hiện được biến thể mới) và Anomaly-based detection (tìm độ lệch so với đường cơ sở (baseline) hành vi thông thường, có thể dùng ngưỡng thống kê hoặc mô hình học máy; ưu điểm phát hiện được hành vi chưa có mẫu biết trước, nhược điểm nhạy với thay đổi tự nhiên của baseline theo thời gian). Báo cáo này áp dụng kết hợp cả hai hướng: signature-based để phát hiện payload nghi vấn trong từng request đơn lẻ request-level), và anomaly-based (ngưỡng thống kê kết hợp Isolation Forest) để phát hiện bất thường về mật độ, phân phối lưu lượng theo khung thời gian.

Một nguyên tắc quan trọng xuyên suốt báo cáo: bất thường không đồng nghĩa với tấn công. Một quan sát bị đánh dấu khác biệt so với baseline có thể do nhiều nguyên nhân lành tính: crawler/bot hợp pháp (Googlebot, Bingbot), đợt tăng lưu lượng đột biến hợp pháp, lỗi ứng dụng, hoặc batch job định kỳ. Do đó, mọi kết luận về loại hình tấn công cụ thể cần được đối chiếu thêm bằng chứng khác (như nguồn IP, ngữ nghĩa URI, tỷ lệ lỗi) trước khi khẳng định, không chỉ dựa vào một điểm số hay một đặc trưng đơn lẻ.

2.3. Cơ sở lý thuyết Isolation Forest

Isolation Forest (Liu, Ting, Zhou, 2008) là thuật toán học không giám sát dựa trên nguyên lý: điểm dữ liệu bất thường vừa chiếm tỷ lệ rất nhỏ, vừa có giá trị đặc trưng khác biệt rõ so với phần còn lại, nên dễ bị cô lập hơn bằng các nhát cắt ngẫu nhiên so với điểm dữ liệu bình thường. Thuật toán xây dựng một rừng gồm nhiều cây cô lập (Isolation Tree) bằng cách lặp lại việc chọn ngẫu nhiên một đặc trưng và một giá trị phân tách nằm giữa min–max của đặc trưng đó, phân tách đệ quy cho tới khi mọi điểm bị cô lập vào nút lá. Vì điểm bất thường có xu hướng bị cô lập, đường đi từ gốc đến lá của nó ngắn hơn đáng kể so với điểm dữ liệu bình thường.

Mức độ bất thường được định lượng bằng công thức:

$$s(x, n) = 2^{-\frac{E(h(x))}{c(n)}}$$

Trong đó:

- $h(x)$ là chiều dài đường đi tới điểm x
- $E(h(x))$ là kỳ vọng chiều dài đường đi qua toàn bộ rừng cây
- $c(n)$ là chiều dài đường đi trung bình chuẩn hoá theo n .
- Nếu $s(x, n) \rightarrow 1$: Điểm dữ liệu bị cô lập rất sớm, được gán nhãn Bất thường / Tấn công (Label = -1).
- Nếu $s(x, n) < 0.5$: Điểm dữ liệu khó bị cô lập, được gán nhãn Bình thường (Label = 1).

Trong thư viện scikit-learn, hàm `decision_function` trả về điểm số đã được tịnh tiến qua một `offset_`: $\text{decision_function} \approx \text{offset_} - s(x, n)$, với giá trị âm biểu thị outlier và giá trị dương biểu thị inlier. Cần lưu ý: `offset_` $\approx 0,5$ chỉ đúng khi tham số `contamination = 'auto'`; khi `contamination` được đặt cố định (ví dụ 0,01 như trong thực nghiệm ở Chương 4), scikit-learn tính `offset_` là phân vị thứ nhất của phân phối điểm số trên tập huấn luyện, không cố định ở 0,5.

Isolation Forest phù hợp với bài toán này vì: không cần dữ liệu có nhãn; độ phức tạp tuyến tính $O(n)$ nhờ kỹ thuật lấy mẫu phụ; không cần tính ma trận khoảng cách giữa mọi cặp điểm như LOF hay One-Class SVM, phù hợp với quy mô log lớn.

2.4. Nguyên tắc bất thường không đồng nghĩa với tấn công

Đây là nguyên tắc xuyên suốt và có ý nghĩa quyết định đối với phần diễn giải kết quả của báo cáo. Một mô hình phát hiện bất thường chỉ trả lời được câu hỏi “điểm dữ liệu này có khác biệt so với phần còn lại hay không”, chứ không trả lời được câu hỏi “sự khác biệt này có phải do tấn công hay không”. Trong môi trường web thực tế, ít nhất bốn nguyên nhân hợp pháp có thể tạo ra bất thường thống kê: hoạt động của các bộ thu thập dữ liệu hợp lệ, hiện tượng tăng tải đột biến do nhiều người dùng thật cùng truy cập, lỗi cấu hình hoặc lỗi ứng dụng phía máy chủ, và các tác vụ xử lý theo lô được lập lịch tự động.

Do đó, đầu ra của mô hình phải được hiểu là một danh sách ưu tiên điều tra, không phải một danh sách sự cố an ninh đã được xác nhận. Mọi kết luận về bản chất tấn công đều cần thêm bằng chứng độc lập, chẳng hạn xác thực nguồn gốc địa chỉ IP hoặc phân tích ngữ nghĩa của đường dẫn được truy cập.

2.5. Kết luận chương 2

Chương này đã trình bày các kiến thức Mạng máy tính (giao thức HTTP, mã trạng thái, hai hướng tiếp cận phát hiện bất thường), cơ sở lý thuyết của mô hình học máy được sử dụng là Isolation Forest và đưa ra nguyên tắc để phân biệt bất thường với tấn công.

Toàn bộ nền tảng này là căn cứ trực tiếp cho việc trích xuất đặc trưng ở Chương 3 và thực nghiệm ở Chương 4.

CHƯƠNG 3: NGUỒN DỮ LIỆU VÀ PHƯƠNG PHÁP TRÍCH XUẤT ĐẶC TRƯNG

3.1. Nguồn dữ liệu và Phương pháp lấy mẫu

3.1.1. Giới thiệu bộ dữ liệu và tính phù hợp với bài toán mạng

Nghiên cứu sử dụng bộ dữ liệu mã nguồn mở "Web Server Access Logs" được thu thập từ môi trường vận hành thực tế của trang web thương mại điện tử Zanbil (zanbil.ir) tại Iran vào năm 2019. Tập dữ liệu này được công bố chính thức trên hệ thống dữ liệu học thuật Harvard Dataverse (Zaker, 2019) và phổ biến qua nền tảng Kaggle, có dung lượng gốc khoảng 3.5 GB - hơn 10.3 triệu dòng log. Việc lựa chọn nguồn dữ liệu từ một nền tảng học thuật uy tín đảm bảo tính minh bạch và độ tin cậy khoa học cho báo cáo.

Dưới góc độ Mạng máy tính, tập dữ liệu này hoàn toàn phù hợp để phân tích các hành vi tại Tầng Ứng dụng (7) vì các lý do sau:

- Tính chuẩn mực của cấu trúc: Dữ liệu gốc tuân thủ định dạng Nginx Combined Log Format - chuẩn nhật ký máy chủ phổ biến nhất trong các hạ tầng mạng doanh nghiệp.
- Tính đa dạng và thực tiễn: Vì là dữ liệu thực tế từ một trang thương mại điện tử, tập dữ liệu chứa đựng cả lưu lượng mạng sạch (người dùng mua sắm, lướt web hợp lệ) và các tín hiệu bất thường lẫn khuất (như các mã lỗi 403, 404, 502, hoặc lưu lượng tăng vọt bất thường từ một số IP cụ thể). Điều này tạo môi trường lý tưởng để huấn luyện mô hình học máy nhận diện các bất thường trong môi trường mạng.

3.1.2. Mô tả bộ dữ liệu sau khi trích xuất

Đơn vị quan sát : Mỗi dòng bản ghi (log) đại diện cho đúng một chu kỳ Yêu cầu - Phản hồi (HTTP Request - Response) giữa thiết bị của người dùng (Client) và máy chủ Web (Server) với đầy đủ các trường tiêu chuẩn (IP, method, URI, status code, bytes).

Số lượng dữ liệu: 100.000 dòng log liên tiếp đầu tiên (tương đương 9.8 MB dữ liệu). Mẫu dữ liệu này kéo dài trong khoảng thời gian vận hành thực tế từ 2019-01-22 03:56:14 đến 2019-01-22 08:01:41

Schema và Data Dictionary:

Variable	Kiểu dữ liệu gốc (Log)	Kiểu dữ liệu chuẩn hóa (CSV)	Ý nghĩa mạng máy tính	Vai trò
IP	String	Categorical / String	Địa chỉ IP nguồn (Client IP Address) định danh thiết bị gửi gói tin HTTP.	Feature
timestamp	String [dd/Mmm/yy yy...]	Datetime (YYYY-MM-DD HH:MM:SS)	Thời điểm máy chủ ghi nhận request.	Feature
method	String	Categorical	Phương thức HTTP (GET, POST, HEAD, OPTIONS) thể hiện loại hành động của Client trên Server.	Feature
uri/ uri_raw	String	String	Đường dẫn tài nguyên mạng được yêu cầu (giữ nguyên và bỏ query string)	Feature
status_code	String / Integer	Integer	Mã trạng thái phản hồi từ Web Server (200 OK, 301, 400, 403, 404, 500...), phản ánh kết quả xử lý giao thức.	Feature

bytes	String / Integer	Integer	Dung lượng dữ liệu trả về cho Client, đo lường mức độ tiêu thụ băng thông mạng.	Feature
--------------	-----------------------------	----------------	---	---------

Bảng 3.1. Data Dictionary của tập dữ liệu sau chuẩn hóa

3.1.3. Phương pháp lấy mẫu chuỗi thời gian liên tục cho bài toán mạng và giới hạn

Tập dữ liệu gốc (access.log) có dung lượng lên tới 3.5 GB, chứa hơn 10.37 triệu dòng sự kiện mẫu dữ liệu thu được trải liên tục từ 03:56:14 đến 08:01:41 ngày 22/01/2019, tương ứng khoảng 4 giờ 5 phút hoạt động của máy chủ. Việc xử lý toàn bộ tập dữ liệu này trên máy tính cá nhân sẽ gây hiện tượng tràn bộ nhớ, đặc biệt là khi thực hiện quy trình trích xuất đặc trưng.

Do đó, nhóm nghiên cứu quyết định trích xuất một mẫu gồm 100.000 dòng log liên tiếp đầu tiên để phục vụ cho mục đích bài toán bằng phương pháp Lấy mẫu chuỗi thời gian liên tục.

Theo nghiên cứu “*Outside the Closed World: On Using Machine Learning for Network Intrusion Detection*”(2010), phương pháp Lấy mẫu chuỗi thời gian liên tục được lựa chọn thay vì lấy mẫu ngẫu nhiên dựa trên ba cơ sở lý luận cốt lõi:

- Bảo toàn ngữ cảnh luồng mạng: Các cuộc tấn công mạng như DoS hoặc rà quét cổng không phải là các sự kiện đơn lẻ mà là một chuỗi hành vi liên tục theo thời gian. Việc lấy mẫu liên tiếp giúp giữ nguyên bối cảnh thời gian, bảo toàn trọn vẹn các phiên kết nối (sessions) và không làm đứt gãy dấu vết lưu lượng.
- Đảm bảo tính đại diện của nhóm dị biệt: Thống kê sơ bộ cho thấy các luồng dữ liệu mang mã lỗi (4xx, 5xx) chiếm khoảng 2% tổng lưu lượng. Việc trích xuất 100.000 dòng sẽ cung cấp khoảng 2.000 quan sát bất thường. Đây là một quy mô mẫu đủ lớn và có ý nghĩa thống kê để các thuật toán Học máy không giám sát (như Isolation Forest) có thể

thiết lập được đường cơ sở (baseline) và phân lập các điểm ngoại lai (outliers) hiệu quả.

- Đo lường chính xác tốc độ yêu cầu: Đánh giá bất thường mạng không chỉ dựa trên tổng số lượng mà phụ thuộc rất lớn vào tốc độ phát sinh trong một đơn vị thời gian. Việc giữ nguyên tính liên tục của các bản ghi giúp mô hình đo lường chính xác đặc trưng tần suất truy cập của từng địa chỉ IP, từ đó phân biệt được đâu là "Flash Crowd" (lưu lượng tăng tự nhiên) và đâu là bất thường.

Tuy nhiên, trong quá trình kiểm tra trực tiếp trên file dữ liệu, nhóm đã phát hiện được giới hạn về tính đại diện theo thời gian cần nêu rõ. Vì mẫu chỉ phủ một buổi sáng của một ngày, các ngưỡng "bình thường" rút ra từ dữ liệu này chỉ phản ánh đúng khung giờ sáng sớm, chưa chắc đại diện cho biến động lưu lượng buổi chiều/tối, cuối tuần hoặc các đợt cao điểm khuyến mãi. Đây là giới hạn dữ liệu cần nêu minh bạch, không phải sai sót có thể khắc phục trong phạm vi báo cáo này.

3.2. Quá trình tiền xử lý dữ liệu

Dữ liệu nhật ký máy chủ ở dạng thô là dữ liệu phi cấu trúc. Để chuyển hóa thành không gian dữ liệu có cấu trúc phục vụ cho các thuật toán Học máy, nhóm nghiên cứu đã xây dựng một quy trình tiền xử lý (ETL - Extract, Transform, Load) với các bước cụ thể như sau:

3.2.1. Bóc tách và ép kiểu dữ liệu

Sử dụng Biểu thức chính quy (Regular Expression - Regex), hệ thống bóc tách chính xác 6 trường dữ liệu cốt lõi từ cấu trúc *Nginx Combined Log*.

Trường **timestamp**: Được cắt chuỗi và ép kiểu sang định dạng chuẩn ISO 8601 (YYYY-MM-DD HH:MM:SS). Đây là bước bắt buộc để tạo trục thời gian liên tục, phục vụ cho kỹ thuật gom cụm theo cửa sổ thời gian ở giai đoạn sau.

Trường **status_code** và **bytes**: Được chuyển đổi từ dạng chuỗi sang dạng số nguyên (Integer) để thực hiện các phép toán thống kê bằng thông.

3.2.2. Xử lý giá trị khuyết thiếu dưới góc độ mạng

Trong chuẩn nhật ký Nginx, khi một phản hồi HTTP không chứa phần thân dữ liệu - thường xảy ra với các mã chuyển hướng (301, 302), các lỗi phía máy khách (4xx) bị Server ngắt kết nối sớm, hoặc các request sử dụng phương thức HEAD - trường bytes sẽ được ghi nhận bằng ký tự gạch ngang (-).

Nếu áp dụng các phương pháp loại bỏ dòng chứa Missing Value thông thường, hệ thống sẽ làm mất đi các bản ghi quan trọng về lỗi mạng. Do đó, phương pháp xử lý ở đây là quy đổi toàn bộ ký tự - về giá trị 0 (byte). Việc gán giá trị 0 hoàn toàn phản ánh đúng thực tế vật lý của mạng: gói tin phản hồi chỉ chứa phần Header mà không có Payload dữ liệu.

3.2.3. Chuẩn hóa đường dẫn tài nguyên URI theo hai cột

Nhóm thực hiện chia trường dữ liệu này làm 02 cột dữ liệu để phục vụ cho quá trình xử lý:

- Cột chuẩn hóa (Không chứa chuỗi truy vấn động): giúp quy đổi các yêu cầu về đúng định danh điểm đích, ngăn chặn hiện tượng phân rã không gian tài nguyên khi cùng một trang sản phẩm bị đếm thành nhiều đường dẫn khác nhau chỉ vì tham số sắp xếp khác nhau. Cột này dùng để tính số lượng đường dẫn riêng biệt.
- Cột gốc (Giữ nguyên chuỗi truy vấn động): phục vụ cơ chế phát hiện dựa trên chữ ký. Do các tấn công chèn mã hầu như luôn truyền tải payload qua tham số động nằm sau dấu hỏi, việc giữ lại chuỗi nguyên bản là điều kiện bắt buộc để không bỏ lọt hành vi xâm nhập.

Trước khi đối sánh chữ ký, toàn bộ chuỗi được giải mã URL và chuyển về chữ thường, nhằm vô hiệu hoá kỹ thuật làm mờ payload bằng mã hoá phần trăm.

3.2.4. Cơ sở lý luận của việc bảo toàn dữ liệu trùng lặp và ngoại lai

Thống kê dữ liệu sau bóc tách cho thấy sự xuất hiện của các điểm ngoại lai (Outliers) cực đoan. Điển hình như địa chỉ IP 66.249.66.194 phát sinh tới 9.331 requests, hay hàng loạt request liên tục trả về mã lỗi 403, 404.

Trong khoa học dữ liệu truyền thống, các dòng trùng lặp hoặc các điểm ngoại lai thường bị xem là nhiễu và bị loại bỏ để tránh làm sai lệch mô hình. Tuy nhiên, theo Giáo trình “Mạng máy tính: Nguyên lý, giao thức, an toàn và phân tích dữ liệu mạng”, việc bảo toàn tuyệt đối 100.000 dòng log thô này là cần thiết bởi 3 cơ sở lý thuyết sau:

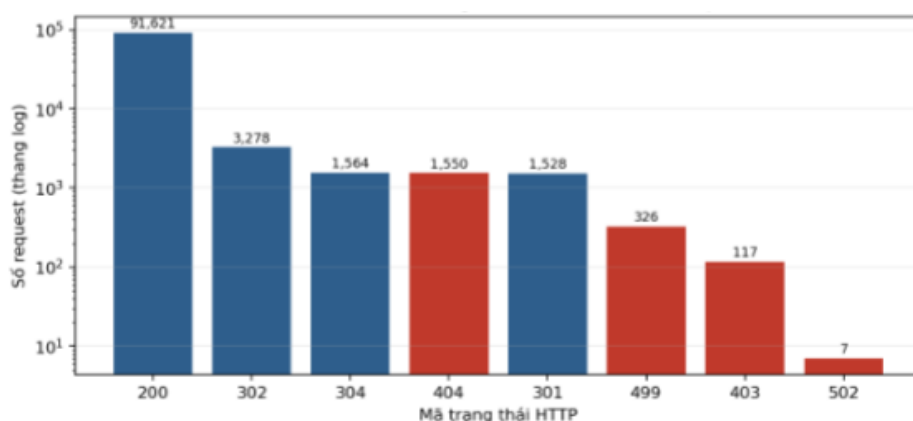
- Tổng hợp Luồng: Theo lý thuyết phân tích lưu lượng, đơn vị quan sát cần được chuyển đổi từ các bản ghi sự kiện rời rạc sang dạng Luồng (Flow/Session) nên cần gom nhóm theo địa chỉ IP và Cửa sổ thời gian (t) để từ đó trích xuất chính xác các đặc trưng tổng hợp.
- Tốc độ Yêu cầu: Giáo trình chỉ ra sự khác biệt căn bản giữa Tổng số lượng (request_count) và Tốc độ phát sinh (request_rate = count / duration). Một địa chỉ IP phát sinh 9.331 requests chỉ bất thường khi xét trong một khoảng thời gian ngắn Δt nên nếu loại bỏ bất kỳ log thô nào sẽ làm sai lệch thời lượng và tốc độ dẫn đến đánh giá sai lệch hành vi mạng.
- Thiết lập đường cơ sở thực tế: Mọi đánh giá bất thường đều cần đối chiếu với đường cơ sở vận hành. Giữ lại các IP có tần suất truy cập cao (như Googlebot, Bingbot) là tình huống thực tế để mô hình Unsupervised Learning có thể thiết lập đúng ranh giới đường cơ sở, từ đó xác định được những bất thường.

3.2.5. Thống kê mô tả sau tiền xử lý

Yếu tố	Thống kê	Đánh giá dưới góc độ mạng
Mã trạng thái	2xx/3xx: ~98,0% (200 OK: 91,62%);	Lưu lượng bình thường chiếm chủ đạo; đủ tín hiệu lỗi để

	4xx: ~2,0% (404: 1.550; 403: 117) 5xx: 10 request	nhận diện dò quét (4xx) hoặc quá tải (5xx)
Phương thức	GET 98.695; HEAD 725; POST 578; OPTIONS 2	Phản ánh đúng đặc thù website thương mại điện tử
Lưu lượng theo IP	Top IP: 66.249.66.194 (9.331), 66.249.66.91 (6.202), 40.77.167.170 (2.292)	Các IP dẫn đầu thuộc dải Googlebot/Bingbot - dữ liệu nền phân biệt bot hợp lệ và bất thường
Số IP riêng biệt	3.987 địa chỉ	Mức phân tán nguồn truy cập đủ lớn để phân tích hành vi theo từng tác nhân
Độ dài URL	Trung vị 32 ký tự; P90 = 152; P95 = 271; P99 = 429; cực đại 1.175 ký tự	Phân phối lệch phải mạnh; giá trị cực đại gợi ý các chuỗi truy vấn dài bất thường cần kiểm tra
Dung lượng phản hồi	Mã 301/404/502: 0 bytes; dải còn lại từ 0 đến hàng trăm KB	Đa dạng kích thước payload, cho phép phát hiện bất thường theo chiều dung lượng

Bảng 3.2. Thống kê dataset sau tiền xử lý



Hình 3.1. Phân bố mã trạng thái HTTP trên 100.000 request (trục tung thang logarit)

3.3. Phương pháp Trích xuất đặc trưng dưới góc độ Mạng

Dữ liệu nhật ký thô sau khi tiền xử lý mới chỉ dừng ở mức độ thông tin định danh sự kiện. Để các thuật toán Học máy có thể nhận diện được các mẫu hình của rủi ro an ninh, hệ thống cần thực hiện Trích xuất đặc trưng. Do đó, nhóm nghiên cứu đã thiết kế một không gian đặc trưng hai cấp độ bao gồm: Cấp độ Yêu cầu đơn lẻ (Request-level) và Cấp độ Cửa sổ IP (IP-Window level).

3.3.1. Đặc trưng cấp độ Request

Tại cấp độ này, mô hình đánh giá độc lập từng gói tin HTTP Request nhằm phát hiện các dấu hiệu độc hại nhúng bên trong Payload (cụ thể là chuỗi URI). Các đặc trưng này nhắm thẳng vào các kỹ thuật tấn công chèn mã hoặc vượt quyền, vốn dĩ có thể thỏa hiệp máy chủ chỉ bằng một kết nối duy nhất.

Đặc trưng `url_length` (Độ dài chuỗi URI): Trong các giao tiếp web thông thường, chuỗi URI thường có độ dài tiêu chuẩn nhằm định tuyến tài nguyên. Việc xuất hiện các request có `url_length` lớn bất thường (vài trăm đến hàng ngàn byte) là chỉ báo kinh điển của nỗ lực nhồi nhét tải trọng độc hại (Payload injection) hoặc tấn công tràn bộ đệm nhằm làm sập trình phân tích cú pháp (Parser) của Web Server.

Đặc trưng `is_suspicious_uri`: Nhóm nghiên cứu xây dựng một bộ lọc Biểu thức chính quy (Regular Expression) áp dụng lên URI đã được giải mã (URL Decode). Bộ lọc này bắt giữ các ký tự cấu trúc vi phạm nguyên tắc truy cập tài nguyên thông thường:

- Dấu hiệu SQL Injection (SQLi): Khai thác cơ sở dữ liệu qua các ký tự ngắt câu lệnh (`%27, '`) hoặc từ khóa (UNION SELECT).
- Dấu hiệu Cross-Site Scripting (XSS): Chèn mã kịch bản hướng Client (`<script>`, `onerror`).
- Dấu hiệu Path Traversal: Nỗ lực duyệt lùi thư mục để truy cập tệp cấu hình hệ thống (`../, ..\`).

Đặc trưng request_interval: Đo lường khoảng thời gian Δt giữa yêu cầu hiện tại và yêu cầu liền trước từ cùng một địa chỉ IP. Các công cụ dò quét tự động thường duy trì một request_interval hội tụ về 0 hoặc dao động dần theo chu kỳ máy móc, trái ngược hoàn toàn với độ trễ phản xạ tự nhiên của người dùng con người.

3.3.2. Đặc trưng cấp độ Cửa sổ IP Window

Bảy đặc trưng (feature) được trích xuất cho mỗi time-window, cùng ý nghĩa dưới góc độ mạng máy tính:

Đặc trưng	Ý nghĩa mạng máy tính
request_count	Tần suất truy cập của IP trong 1 phút. Giá trị cao bất thường gợi ý quét tự động (scan), crawl hàng loạt hoặc tấn công dạng flood.
error_4xx_rate	Tỷ lệ request bị từ chối/không tồn tại (404, 403...). Tỷ lệ cao gợi ý dò quét đường dẫn (path traversal/ brute-force endpoint).
error_5xx_rate	Tỷ lệ request khiến server lỗi nội bộ. Cao bất thường có thể là dấu hiệu khai thác lỗi ứng dụng hoặc quá tải server.
avg_payload_bytes / max_payload_bytes	Kích thước dữ liệu trao đổi trung bình/tối đa. Bất thường có thể là tải file lớn, exfiltrate dữ liệu, hoặc lỗi trả về trang lỗi/nội dung lớn không mong muốn.
unique_uri_count	Số đường dẫn (URL) riêng biệt được truy cập. Cao bất thường gợi ý dò quét cấu trúc website (directory/content discovery).

suspicious_flag_count	Số request chứa ký tự/mẫu nghi vấn trong URI (dấu hiệu SQL Injection, XSS...), do Thành viên 2 gắn cờ ở bước trích xuất đặc trưng.
------------------------------	--

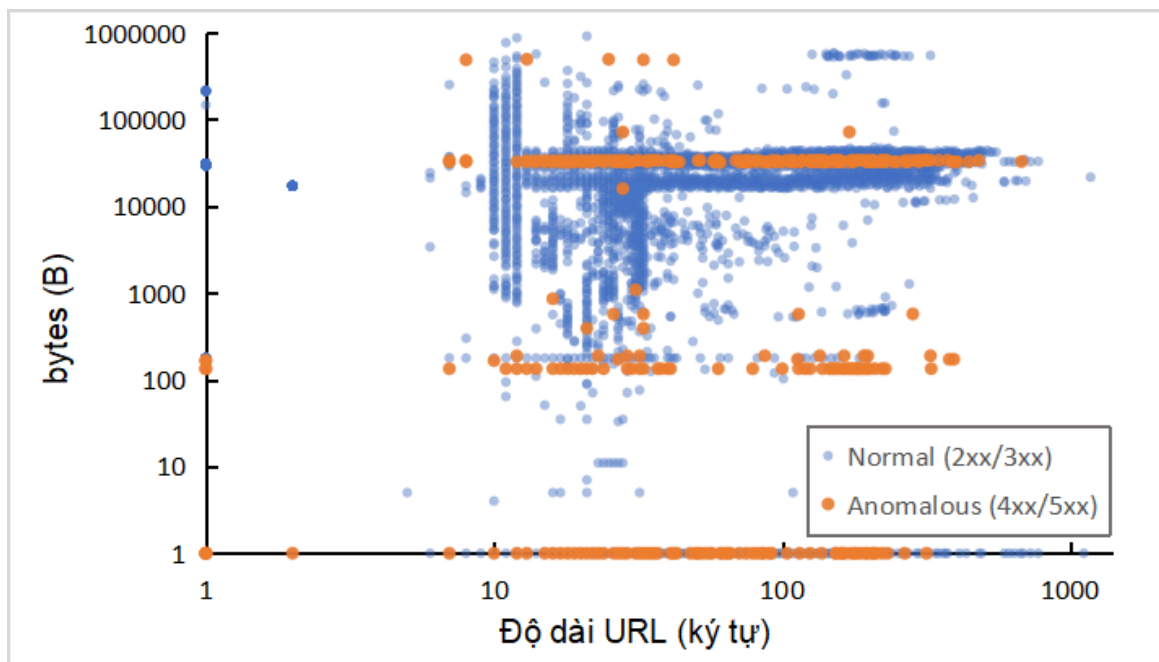
Bảng 3.3. Đặc trưng đầu vào của mô hình phát hiện bất thường

3.4. Tinh chỉnh quy tắc phát hiện URI nghi ngờ (is_suspicious_uri) phát hiện quan trọng từ EDA (Exploratory Data Analysis)

Bộ quy tắc trong request.py được viết theo ngữ cảnh: loại bỏ hoàn toàn các pattern đơn lẻ dễ gây nhiễu, chỉ giữ lại các pattern có ngữ cảnh rõ ràng, gần với kỹ thuật tấn công thật sự - ví dụ dấu nháy đơn đi kèm ngay sau đó là comment SQL (%27...--/%23/#), các từ khóa SQL có cấu trúc (union select, or 1=1, drop table, select ... from), thẻ <script>, javascript:, onerror=/onload=, path traversal (.././, /etc/passwd), null byte, hoặc lệnh hệ thống (cmd.exe, rm -rf, nc -e).

Kết quả: trên toàn bộ 99.527 request (không tính những request đã được xác định là duplicate), phiên bản quy tắc mới (request.py) không còn ghi nhận request nào bị gắn cờ is_suspicious_uri = 1, cho thấy dữ liệu log thực tế này chủ yếu là traffic bình thường của một website thương mại điện tử, không chứa payload tấn công rõ ràng ở mức URI. Đây là một kết luận EDA quan trọng, đồng thời minh họa trực tiếp cho giới hạn & an toàn: không thể tự động kết luận có tấn công chỉ vì một pattern đơn lẻ xuất hiện.

3.5. Minh họa kết quả.



Hình 3.2. Tương quan giữa độ dài URL và dung lượng gói tin phản hồi giữa request bình thường (2xx/3xx) và bất thường (4xx/5xx)

Biểu đồ thể hiện mối tương quan giữa độ dài của chuỗi URI được gửi đi và kích thước payload phản hồi từ Web Server, giúp bóc tách rõ hành vi của các truy cập hợp lệ và bất thường.

Hành vi bình thường (Normal 2xx/3xx - Chấm xanh): Các truy cập hợp lệ phân bố chủ yếu ở khoảng URL có độ dài tiêu chuẩn (từ 10 đến 100 ký tự) và nhận về các cụm dữ liệu phản hồi khá dày đặc ở mức hàng chục KB đến hàng trăm KB. Đây là kích thước bằng thông điển hình khi tải các tệp tin tĩnh (HTML, CSS, JS, Image) của một website thông thường.

Dấu hiệu dò quét và nhồi nhét Payload (URL siêu dài): Đáng chú ý ở trục hoành, xuất hiện các request mang mã lỗi (Anomalous - Chấm cam) có độ dài URL lớn (từ 100 đến gần 1000 ký tự). Dưới góc độ mạng, việc máy khách (client) gửi các gói tin HTTP GET với phần URI dài bất thường là dấu hiệu kinh điển của việc cố tình nhồi nhét mã độc (SQL Injection, XSS) trực tiếp vào thanh địa chỉ, hoặc nỗ lực gây lỗi tràn bộ đệm (Buffer Overflow) trên Web Server.

Cơ chế phản hồi từ chối (Gói tin siêu nhỏ): Nhìn vào trực tung, có một dải ngang các điểm lỗi (màu cam) tập trung ở mức dung lượng phản hồi rất thấp (quanh mốc 100B - 200B). Phản hồi với gói tin siêu nhỏ đi kèm mã 4xx/5xx chứng tỏ cấu hình định tuyến của Web Server (hoặc Web Application Firewall) đã hoạt động hiệu quả. Hệ thống đã lập tức ngắt kết nối đối với các request độc hại hoặc không tồn tại này và chỉ trả về một đoạn HTTP Header hoặc trang lỗi rút gọn (như 403 Forbidden / 404 Not Found), chặn đứng việc rò rỉ dữ liệu hệ thống ra ngoài.

3.6. Hạn chế và lưu ý khi sử dụng đặc trưng

Timestamp nguồn chỉ có độ phân giải phút, ảnh hưởng tới độ chính xác của request_interval ở mức giây và có thể làm sai lệch nhẹ bước loại bỏ duplicate; nếu log gốc có độ phân giải giây, nên cập nhật `TIMESTAMP_FORMAT` trong request.py để cải thiện độ chính xác.

Bộ quy tắc `is_suspicious_uri` là heuristic dựa trên regex, chỉ hỗ trợ feature engineering, không phải bộ phát hiện tấn công hoàn chỉnh; việc không phát hiện request nghi ngờ nào không đồng nghĩa log an toàn tuyệt đối, chỉ phản ánh không có payload khớp các pattern đã định nghĩa.

3.7. Kết luận chương 3

Chương 3 đã hoàn thiện toàn bộ quy trình chuẩn bị dữ liệu và kỹ thuật đặc trưng dưới góc nhìn mạng máy tính, làm nền tảng đầu vào cho mô hình học máy:

Thứ nhất, về tính đại diện và toàn vẹn của dữ liệu, mẫu dữ liệu gồm 100.000 bản ghi chuỗi thời gian liên tục từ nhật ký máy chủ Zabbix được lựa chọn để bảo toàn cấu trúc luồng (flow) và bối cảnh các phiên kết nối. Toàn bộ các giá trị ngoại lai và bản ghi lỗi mạng (4xx, 5xx) được giữ lại nguyên vẹn

thay vì loại bỏ, phản ánh đúng cơ sở vận hành thực tế và bảo đảm dữ liệu nền cho việc thiết lập baseline phát hiện bất thường.

Thứ hai, về quy trình ETL chuẩn hóa, quá trình tiền xử lý đã chuyển hóa thành công dữ liệu nhật ký phi cấu trúc thành dữ liệu có cấu trúc qua việc bóc tách Regex, ép kiểu thời gian ISO 8601, quy đổi dung lượng byte của các gói tin chỉ có header về 0, và phân tách URI thành hai dạng (gốc và chuẩn hóa) để vừa kiểm soát không gian tài nguyên vừa bảo toàn dấu vết payload.

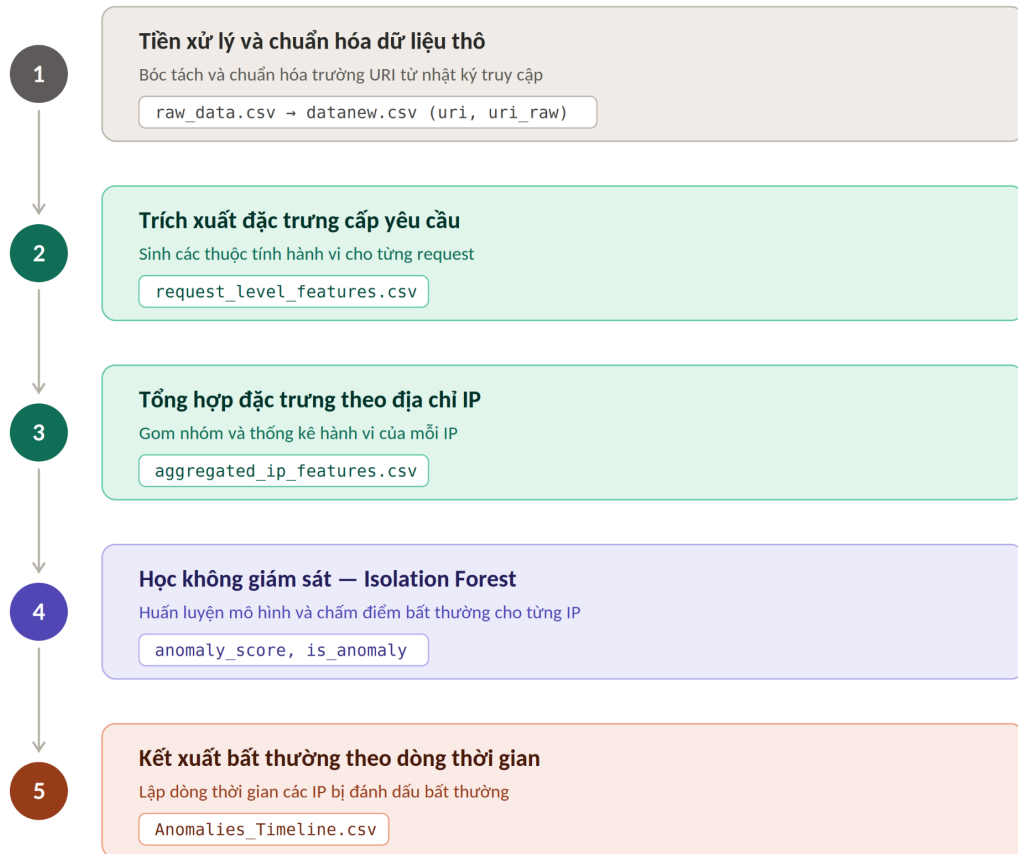
Thứ ba, về không gian đặc trưng hai cấp độ request và cửa sổ thời gian IP. Với cấp độ Request, đã khảo sát các thuộc tính đơn lẻ như độ dài URI (`url_length`), khoảng cách thời gian (`request_interval`) và cờ cảnh báo mẫu tấn công (`is_suspicious_uri`). Qua phân tích khám phá (EDA), bộ quy tắc lọc regex đã được tinh chỉnh theo ngữ cảnh để triệt tiêu báo động giả do phân cách chuỗi tiếng Farsi. Với cấp độ Cửa sổ thời gian IP (IP-Window), đã trích xuất 7 đặc trưng thống kê hành vi (tần suất yêu cầu, tỷ lệ lỗi 4xx/5xx, dung lượng trao đổi trung bình/tối đa, số URL duy nhất, số cờ nghi vấn) trong cửa sổ 1 phút, giúp mô hình hóa rõ nét sự khác biệt giữa lưu lượng bot hợp lệ (Googlebot/Bingbot) và các hành vi dò quét, flood bất thường.

Thứ tư, về định vị giới hạn nghiên cứu, nghiên cứu xác định rõ các ràng buộc về độ bao phủ khung thời gian, độ phân giải của nhãn thời gian và bản chất heuristic của bộ lọc regex. Những giới hạn này là cơ sở quan trọng để diễn giải đúng kết quả thực nghiệm.

Toàn bộ tập đặc trưng đa chiều đã trích xuất tại Chương 3 là cơ sở dữ liệu đầu vào trực tiếp để triển khai huấn luyện, đánh giá và so sánh hiệu năng của các thuật toán phát hiện bất thường trong Chương 4.

CHƯƠNG 4: XÂY DỰNG CHƯƠNG TRÌNH VÀ THỰC NGHIỆM MÔ HÌNH

4.1. Kiến trúc pipeline tổng thể



Hình 4.1. Kiến trúc quy trình tổng thể

4.2. Mô hình Học không giám sát (Isolation Forest)

4.2.1. Đặt vấn đề & mục tiêu

4.2.1.1. Đặt vấn đề

Trong bối cảnh an toàn thông tin mạng, hệ thống máy chủ liên tục ghi nhận khối lượng khổng lồ dữ liệu nhật ký truy cập (Web Logs). Mặc dù chứa đựng toàn bộ vết tích của các tác nhân tương tác với hệ thống, việc khai phá tập dữ liệu nhằm phát hiện các mối đe dọa gặp phải ba thách thức kỹ thuật cốt lõi:

- Dữ liệu log thô sinh ra trong môi trường thực tế hoàn toàn không có sẵn nhãn phân loại bình thường (Normal) hay bất thường (Anomaly). Điều này khiến các mô hình học máy có giám sát (Supervised Learning) truyền thống khó có thể triển khai trực tiếp nếu không có một tập dữ liệu mẫu chuẩn (baseline) hoặc quá trình gán nhãn trước.
- Lưu lượng mạng chứa hành vi độc hại (như DDoS, Web Vulnerability Scanning, Injection) chỉ chiếm một tỷ lệ rất nhỏ (thường dưới 5%) so với tổng lưu lượng hợp lệ. Các điểm dữ liệu này ẩn mình dưới dạng các điểm ngoại lai trong không gian nhiều chiều.
- Nếu chỉ đánh giá từng dòng log một cách độc lập, hệ thống sẽ bỏ lọt các cuộc tấn công phân tán hoặc các hành vi rà quét âm thầm. Việc nhận diện tấn công bắt buộc phải được đặt trong một không gian ngữ cảnh và chuỗi thời gian.

4.2.1.2. Mục tiêu

Nhằm giải quyết các rào cản trên, nghiên cứu này áp dụng phương pháp Học máy không giám sát (Unsupervised Machine Learning) để tự động hóa quá trình phát hiện bất thường. Các mục tiêu cụ thể bao gồm:

- Áp dụng kỹ thuật gom nhóm theo cửa sổ thời gian (Time-window Aggregation) để tổng hợp các request đơn lẻ thành các vector đặc trưng hành vi đại diện cho từng địa chỉ IP (ví dụ: tần suất truy cập, tỷ lệ lỗi, độ phân tán URI).
- Ứng dụng thuật toán Isolation Forest để đo lường mức độ cô lập của từng IP trong không gian dữ liệu mới, từ đó tự động phân tách nhóm hành vi hợp lệ và nhóm hành vi mang đặc tính của tấn công mạng.
- Tập dữ liệu chứa Anomaly gồm có các ip rủi ro cao cung cấp dữ liệu định lượng, hỗ trợ trực tiếp cho quá trình phân tích tình báo mối đe dọa ở các bước tiếp theo.

4.2.2. Phương pháp xây dựng không gian đặc trưng

Để chuyển đổi từ dữ liệu chuỗi thời gian thô (dạng log từng dòng) sang không gian dữ liệu có cấu trúc phù hợp cho thuật toán học máy, nghiên cứu áp dụng kỹ thuật Gom cụm theo Cửa sổ thời gian (Time-window Aggregation).

Phương pháp này không đánh giá các truy cập đơn lẻ mà đánh giá tổng thể của một tác nhân mạng trong một khoảng thời gian xác định.

4.2.2.1. Không gian phân tích và Cửa sổ thời gian

Hệ thống định nghĩa chu kỳ phân tích (Time-window) $\Delta t = 1$ phút. Tất cả các bản ghi nhật ký phát sinh từ cùng một địa chỉ IP nguồn i trong khoảng thời gian Δt sẽ được tổng hợp thành một điểm dữ liệu duy nhất.

```
# Đọc dữ liệu raw đã được xử lý
df = pd.read_csv('request_level_features.csv')
# Ép kiểu timestamp về datetime để xử lý khung thời gian
df['timestamp'] = pd.to_datetime(df['timestamp'])
df['time_window'] = df['timestamp'].dt.floor('1min')
```

4.2.2.2. Vector đặc trưng đa chiều

Mỗi địa chỉ IP i tại chu kỳ t được biểu diễn bằng một vector đặc trưng 7 chiều (Bảng 3.3.2). Các thành phần của vector được trích xuất nhằm mô hình hóa toàn diện ba khía cạnh của mạng: Tần suất (Frequency), Trạng thái phản hồi (Response Status), và Kích thước dữ liệu (Payload Size).

Phương trình vector đặc trưng được biểu diễn như sau:

$$X_{i,t} = [f_{rep}, f_{4xx}, f_{5xx}, f_{avg_bytes}, f_{max_bytes}, f_{uri}, f_{susp}]$$

Dữ liệu gồm 7 đặc trưng theo Time-window.

```
aggregated_df.to_csv('aggregated_ip_features.csv', index=False)
```

Truy cập dữ liệu.

```
agg_df = pd.read_csv('aggregated_ip_features.csv')
```

Xác định tập features cho bước Unsupervised.

```
features = [  
    'request_count', 'error_4xx_rate', 'error_5xx_rate',  
    'avg_payload_bytes', 'max_payload_bytes',  
    'unique_uri_count', 'suspicious_flag_count'  
]  
X = agg_df[features]
```

4.2.3. Cơ sở Lý thuyết & Thuật toán

4.2.3.1. Mô hình Isolation Forest

Thay vì lập mô hình phân phối của dữ liệu bình thường để tìm ra các điểm lệch chuẩn (như PCA hay SVM), Isolation Forest (iForest) trực tiếp cô lập các điểm bất thường.

Thuật toán dựa trên hai đặc tính cơ bản của dữ liệu dị thường:

1. Chiếm tỷ lệ rất nhỏ trong tập dữ liệu.
2. Có giá trị đặc trưng nằm xa các điểm dữ liệu thông thường.

Cơ chế hoạt động: Thuật toán xây dựng một rừng gồm nhiều cây quyết định ngẫu nhiên (Isolation Trees - iTrees) thông qua các bước:

1. Lấy mẫu phụ (sub-sample) ngẫu nhiên từ tập dữ liệu ban đầu.

2. Tại mỗi nút của cây, chọn ngẫu nhiên một đặc trưng (feature) của dữ liệu.

3. Chọn ngẫu nhiên một giá trị phân tách (split value) nằm giữa mức lớn nhất (max) và nhỏ nhất (min) của đặc trưng đó.

4. Tiếp tục phân tách đệ quy cho đến khi mọi điểm dữ liệu bị cô lập hoàn toàn vào các nút lá (hoặc đạt độ sâu giới hạn).

Vì các điểm bất thường nằm tách biệt, chúng sẽ bị cô lập rất nhanh chỉ sau vài lần chia. Do đó, đường đi từ gốc đến lá của điểm bất thường sẽ ngắn hơn đáng kể so với dữ liệu bình thường.

4.2.3.2. Cấu hình các siêu tham số cốt lõi

1. `n_estimators` (Số lượng cây)

Bản chất: Số lượng Isolation Tree được tạo ra trong hệ thống

Giá trị mặc định là 100. Đối với Access Log (thường có dung lượng lớn), 100 cây phù hợp để điểm Anomaly Score hội tụ và ổn định. Tăng lên 200 hay 300 có thể làm mượt kết quả đôi chút nhưng đánh đổi bằng việc suy giảm hiệu suất xử lý thực tế của Web Server.

2. `max_samples` (Kích thước mẫu con)

Bản chất: Số lượng dữ liệu được rút trích ngẫu nhiên từ tập gốc để xây dựng một cây đơn lẻ.

Mặc định là `auto` (giới hạn ở mức 256 mẫu). Khác với các thuật toán khác, Isolation Forest không cần dùng toàn bộ dữ liệu để xây cây. Nếu đưa quá nhiều log bình thường vào, các request tấn công sẽ bị che khuất. Lấy mẫu nhỏ ngẫu nhiên giúp duy trì sự thừa thớt của các điểm bất thường, giúp nhất cắt phát huy tối đa sức mạnh.

3. **contamination** (Tỷ lệ bất thường dự kiến)

Bản chất: Định mức % dữ liệu ước tính là các luồng tấn công trong file log. Dao động từ 0 đến 0.05 (hoặc **auto**).

Tham số này hoạt động như một ngưỡng phân định (threshold). Sau khi tính điểm bất thường cho toàn bộ log, mô hình sẽ chốt hạ lấy top phần trăm cao nhất (theo đúng giá trị **contamination** bạn cấu hình) để gán nhãn -1 (Tấn công).

Triển khai thuật toán Isolation Forest

```
model = IsolationForest(n_estimators=100, contamination=0.01,  
random_state=42)
```

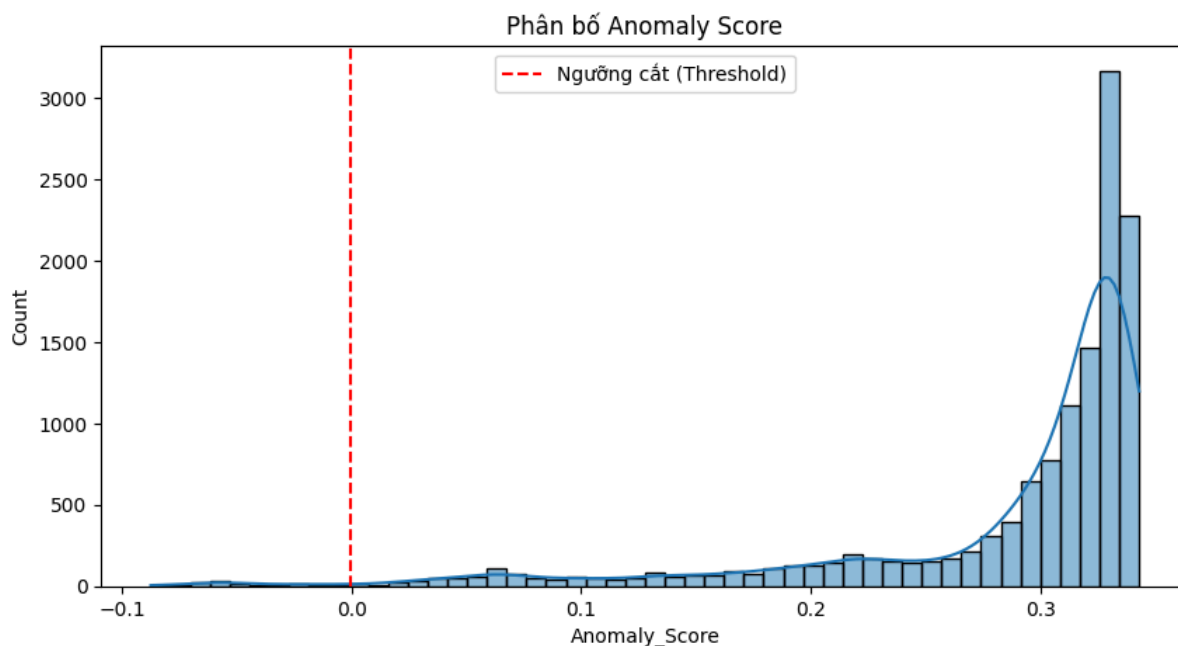
Cấu hình mô hình đã sử dụng:

- `n_estimators = 100`: Số lượng cây trong rừng cô lập; càng nhiều cây thì điểm số càng ổn định, ít phụ thuộc vào yếu tố ngẫu nhiên của một cây đơn lẻ.
- `contamination = 0.01`: Giả định chủ quan rằng khoảng 1% số time-window trong dữ liệu là bất thường; đây là tham số quyết định để xác định ngưỡng cắt (threshold) trên phân bố điểm số, không phải một con số đo được khách quan từ dữ liệu.
- `random_state = 42`: Cố định hạt giống ngẫu nhiên để kết quả có thể tái lập (reproducible) giữa các lần chạy.

4.2.3.2. Lý do xác định chỉ số **contamination**

Chỉ số **contamination** = 0.01 được lựa chọn trên 3 cơ sở

- Phân tích Phân bố Anomaly Score:



Hình 4.2. Phân bố *Anomaly Score*

Ngưỡng cắt nằm ở mức 0.0, cắt đúng phần đuôi phân tách bên trái. Điều này chứng minh mô hình tối ưu hóa được tỷ lệ False Positive (không vết dữ liệu bình thường).

- Định lượng Đặc trưng Normal và nhóm Anomaly

Đặc trưng	Normal	Anomaly	Chênh lệch (lần)	Diễn giải nhanh
request_count	6,97	74,45	10,7x	Tần suất truy cập
error_4xx_rate	0,017	0,054	3,1x	Tỷ lệ lỗi phía client
avg_payload_bytes	16.229	184.749	11,4x	Dung lượng TB
max_payload_bytes	27.831	297.529	10,7x	Dung lượng đỉnh
unique_uri_count	6,25	67,37	10,8x	Độ rộng quét URL

suspicious_flag_count	0,006	0,191	31,3x	Ký tự nghi vấn SQLi/XSS
------------------------------	-------	-------	-------	----------------------------

Bảng 4.1. So sánh giá trị trung bình đặc trưng giữa nhóm Normal và Anomaly

request_count: Nhóm Anomaly có số request trung bình (~74.4) cao gấp hơn 10 lần so với nhóm Normal (~6.9). Đây là dấu hiệu rõ ràng của các hành vi như quét lỗi hoặc tấn công từ chối dịch vụ.

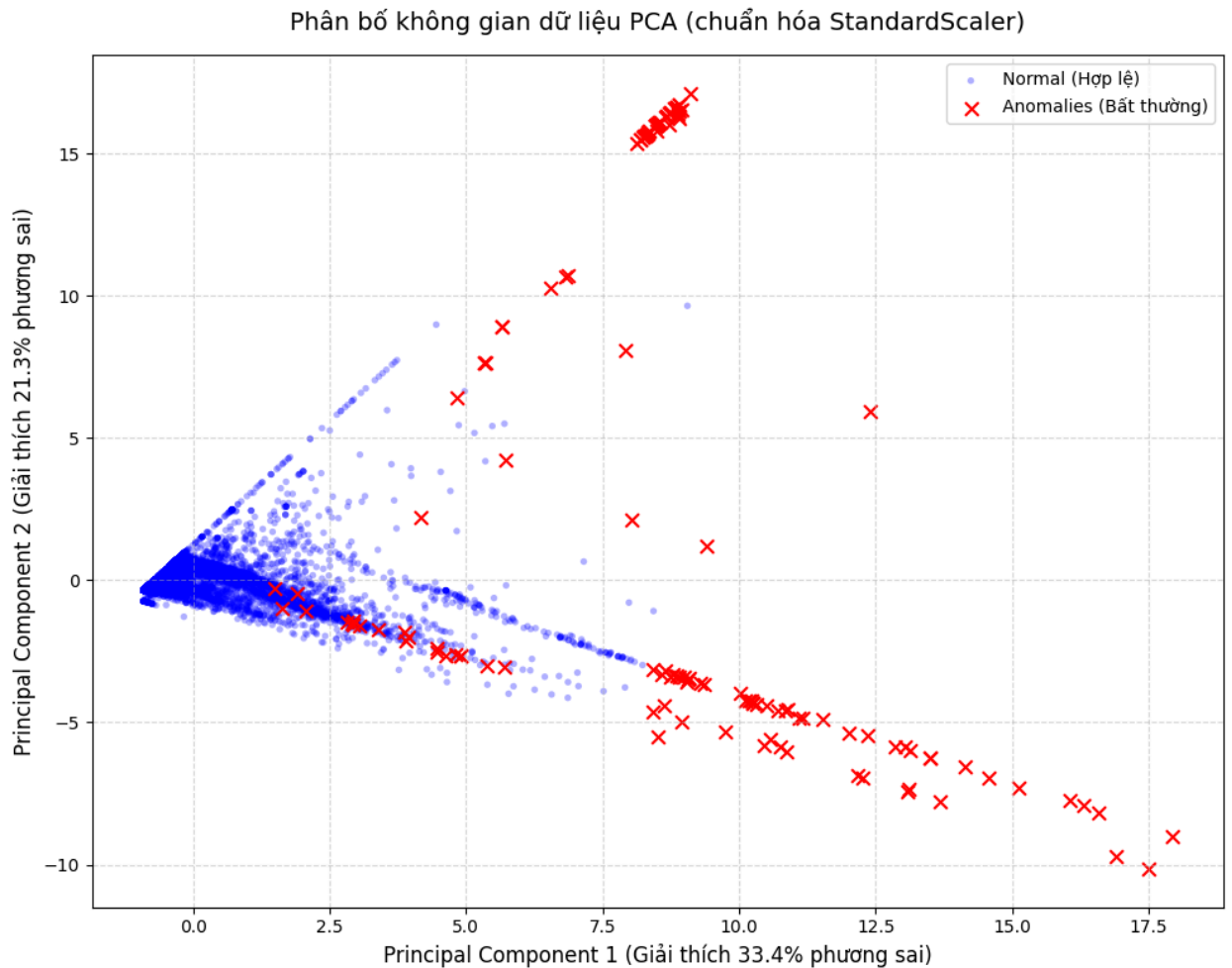
error_4xx_rate: Nhóm Anomaly có tỷ lệ lỗi 4xx (~0.053) cao hơn đáng kể so với nhóm Normal (~0.017).

unique_uri_count: Tương tự, nhóm Anomaly truy cập trung bình ~67.3 URI khác nhau, so với chỉ ~6.2 của nhóm Normal. Điều này phản ánh hành vi dò quét diện rộng.

suspicious_flag_count: Đặc biệt, cờ nghi vấn ở nhóm Anomaly (~0.19) cao vọt so với nhóm Normal (~0.006), cho thấy mô hình đã gom đúng các request chứa ký tự lạ (như SQLi/XSS)

Nhìn từ góc độ thống kê, mô hình đang bóc tách đúng bản chất của các cuộc tấn công. Ngưỡng **contamination** hiện tại được chọn lọc phù hợp.

- Phân bố không gian dữ liệu PCA



Hình 4.3. Phân bố không gian dữ liệu PCA (chuẩn hóa StandardScaler)

Sau khi áp dụng Standardization và nén không gian 7 chiều xuống 2 chiều thông qua PCA, cấu trúc phân tách của mô hình được bộc lộ rõ rệt. Biểu đồ phân tán cho thấy các luồng truy cập hợp lệ (Normal) tập trung thành một lõi mật độ cao. Trái lại, các điểm dữ liệu bị Isolation Forest gán nhãn bất thường (Anomaly) đều nằm hoàn toàn ở vùng ngoại vi và bám theo các đuôi phân bố. Việc không có điểm bất thường nào bị nhận diện nhầm vào vùng lõi là minh chứng trực quan khẳng định tham số giới hạn ngoại lai đã được tối ưu.

4.2.4. Hoạt động của thuật toán

4.2.4.1. Code biểu diễn thuật toán

```
agg_df['Anomaly_Score'] = model.decision_function(X)    # Tính toán
điểm anomaly_score của từng điểm dữ liệu
agg_df['Label'] = model.fit_predict(X)                  # Gán nhãn 1:
Normal, -1: Anomaly
```

Label và Anomaly_Score:

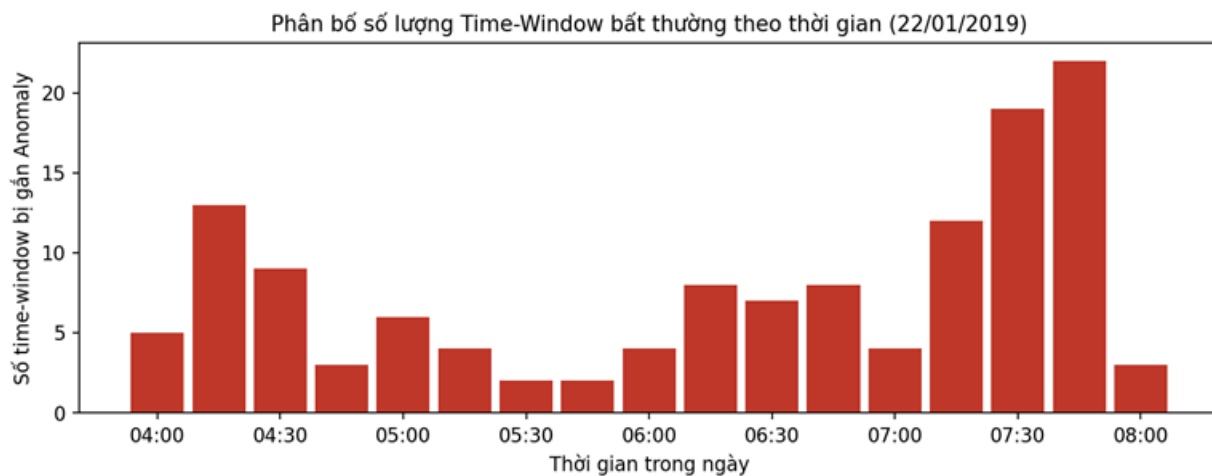
- Label = -1 / Label_Text = “Anomaly”: time-window bị mô hình xem là khác biệt so với phần lớn dữ liệu còn lại đây là tín hiệu “cần chú ý”, chưa phải là kết luận attack.
- Label = 1 / Label_Text = “Normal”: time-window có hành vi tương tự đa số các IP khác trong khung giờ quan sát.
- Anomaly_Score: giá trị càng âm thì mô hình càng chắc chắn đây là điểm khác biệt; giá trị càng gần 0 hoặc dương thì càng giống hành vi phổ biến. Là thước đo mức độ, không phải xác suất tấn công.

4.2.4.2. Kết quả tổng quan

Chỉ số	Giá trị
Khoảng thời gian dữ liệu quan sát	22/01/2019, 03:56–08:01 (khoảng 4 giờ 05 phút)
Số time-window (đơn vị phân tích)	13.076 (tổ hợp IP × phút)
Số IP riêng biệt trong toàn bộ dữ liệu	3.987
Số time-window bị gán Anomaly	131 ($\approx 1,00\%$ tổng số time-window khớp với contamination = 0,01 đã đặt)
Số IP riêng biệt xuất hiện trong nhóm Anomaly	65 (một số IP bị gán Anomaly nhiều lần liên tiếp)

Bảng 4.2. Thống kê tổng quan kết quả phát hiện bất thường

4.2.4.3. Phân bố bất thường theo thời gian (Timeline)



Hình 4.4. Số lượng time-window bị gấn Anomaly theo từng khung 15 phút

4.2.4.4. Các time_window và IP đáng chú ý

a) Top 5 time-window có Anomaly_Score thấp nhất

IP	Time-window	Req/phút	%4xx	Payload TB (byte)	Score	Sample_URI (rút gọn)
172.104.154.208	05:59	2	50%	298.438	-0,0874	/product/31850/62048/...
172.104.154.208	07:07	2	50%	296.916	-0,0874	/product/32374/62714/...
172.104.154.208	07:28	2	50%	286.911	-0,0864	/product/32784/63244/...
194.94.127.7	07:38	268	0%	5.521	-0,0856	/static/images/exists.png

2.188.26.231	07:52	213	0,5%	6.382	-0,0801	/image/218/brand
--------------	-------	-----	------	-------	---------	------------------

Bảng 4.3. Top time-window có mức độ bất thường cao nhất theo Anomaly_Score

b, Top 3 IP bị gán Anomaly lặp lại nhiều lần nhất

IP	Số lần bị gán Anomaly	Req/phút cao nhất	%4xx cao nhất	Payload cao nhất (byte)
46.4.203.149	33	3	0%	584.470
66.249.66.194	18	68	39,1%	49.348
23.101.169.3	10	210	0%	185.207

Bảng 4.4. IP có tần suất xuất hiện lặp lại nhiều nhất trong danh sách bất thường

4.2.4.5. Phân loại sơ bộ

Nhóm nguyên nhân	Bằng chứng trong dữ liệu	Kết luận đề xuất
Crawler hợp lệ	IP 66.249.66.194 xuất hiện 18/131 lần, thuộc dải IP đã công bố của Googlebot; %4xx cao (39%) do bot dò các link không còn tồn tại hành vi crawler thông thường.	False Positive nên loại khỏi danh sách nghi vấn hoặc gán nhãn riêng “bot đã biết”.
Tăng tải đột biến hợp lệ (flash crowd / tải tài nguyên tĩnh)	194.94.127.7, 5.237.115.31, 23.101.169.3: request/phút rất cao (200–268) nhưng %4xx = 0% và toàn bộ Sample_URI là ảnh/tài nguyên tĩnh (/static/images/..., /image/.../productModel/...).	Nhiều khả năng False Positive, nhiều người dùng cùng tải ảnh sản phẩm, không có dấu hiệu lỗi hay dò quét.

Bất thường về payload / lỗi ứng dụng	172.104.154.208: chỉ 2 request/phút nhưng payload TB ~290–298KB và %4xx = 50%; URI chứa chuỗi ký tự đã bị mã hoá phi chuẩn (tiếng Ba Tư bị lỗi encode). 34.252.98.184 và 54.91.182.97 cùng truy vấn /ads.txt với payload 243.809 byte và %4xx = 50%.	Chưa đủ căn cứ kết luận tấn công cần Thành viên 1/2 kiểm tra lại cấu hình server/encoding; tạm gắn nhãn “cần điều tra thêm”.
Dò quét / thăm dò điểm yếu (khả nghi thật sự)	196.64.216.172 và 110.23.220.125 cùng truy vấn /wp-login.php (trang không thuộc kiến trúc site); 31.184.130.52 có %4xx = 100% tại /product/34423; 144.76.119.99 truy vấn /robots.txt với %4xx bất thường.	Nghi vấn cao nhất trong 4 nhóm nên đưa vào phần phát hiện đáng chú ý, kèm khuyến nghị theo dõi/khoá IP.

Bảng 4.5. Phân loại sơ bộ nguyên nhân của các time-window bị gắn Anomaly

4.2.4.6. Giới hạn của phương pháp

Isolation Forest là mô hình không giám sát thuần túy dựa trên độ hiếm/khác biệt trong không gian đặc trưng, mô hình không biết khái niệm về tấn công mạng, do đó không thể tự phân loại loại hình bất thường (DDoS, SQL Injection, Directory Traversal...).

Ngưỡng contamination = 0,01 là một giả định chủ quan được đặt trước, không phải tỷ lệ tấn công thực tế đo được. Nếu đổi tham số này, số lượng và ranh giới Normal/Anomaly sẽ thay đổi. Trong quá trình thực hiện thuật toán cần xác định ngưỡng contamination bằng 3 bước xác thực như ở trên. Cần thời gian kiểm định ngưỡng contamination phù hợp để thuật toán có thể phát huy được đúng sức mạnh của thuật toán.

4.2.5. Kết quả

(Anomalies_Timeline.csv): Anomalies_Timeline.csv: chi tiết từng **window** bị gán Anomaly, theo thời gian. Giúp phân tích và phân loại các loại hình bất thường và đề xuất hướng xử lý phù hợp.

Thiết lập ma trận 7 đặc trưng đại diện cho Tần suất, Trạng thái phản hồi và Kích thước dữ liệu trên 13.076 cửa sổ thời gian IP_Window. Mô hình Isolation Forest với cấu hình $n_estimators=100$ và $contamination=0.01$ được thẩm định chặt chẽ qua phân bố Anomaly Score, không gian nén PCA và bảng so sánh đặc trưng (nhóm Anomaly có tần suất truy cập cao gấp 10,7 lần, cờ nghi vấn cao gấp 31,3 lần so với nhóm Normal).

Mô hình đã lọc ra 131 time-window dị biệt (thuộc 65 IP nguồn) và xuất file nhật ký Anomalies_Timeline.csv. Phân tích định lượng sơ bộ đã bóc tách danh sách này thành 4 nhóm nguyên nhân thực tế: Bot/Crawler hợp lệ (như Googlebot), Tăng tải đột biến hợp lệ (Flash Crowd tải tài nguyên tĩnh), Bất thường payload/mã hóa ứng dụng, và các hành vi Dò quét/Thăm dò lỗ hổng.

4.3. Kết luận chương 4

Chương 4 đã hoàn thành thực nghiệm mô hình phát hiện hành vi bất thường với các kết quả cốt lõi:

1. Thiết lập Pipeline & Không gian đặc trưng: Xử lý 13.076 cửa sổ thời gian (IP-Window 1 phút) thành các vector 7 chiều phản ánh tần suất, mã lỗi, dung lượng và cờ nghi vấn.
2. Tối ưu & Thẩm định mô hình: Triển khai Isolation Forest ($n_estimators=100$, $contamination=0.01$), xác nhận tính tối ưu qua phân bố Anomaly Score, biểu đồ PCA 2D và bảng chênh lệch đặc trưng giữa hai nhóm Normal/Anomaly.
3. Bóc tách 4 nhóm nguyên nhân thực tế: Phân loại 131 time-window bất thường (65 IP nguồn) thành: (1) Crawler hợp lệ (Googlebot), (2) Flash

Crowd tài nguyên tĩnh, (3) Bất thường mã hóa/payload, và (4) Dò quét điểm yếu thực sự.

4. Định vị giá trị ứng dụng: Xuất dữ liệu Anomalies_Timeline.csv đóng vai trò là bộ lọc ưu tiên điều tra sự cố, tuân thủ nguyên tắc "Bất thường không đồng nghĩa với Tấn công".

Kết quả của Chương 4 đã chỉ ra giới hạn cốt lõi của mô hình không giám sát: *bất thường thống kê không đồng nghĩa với tấn công mạng*. Đây là tiền đề trực tiếp để Chương 5 tiến hành phân tích chuyên sâu các trường hợp báo động giả, đối chiếu hiệu năng giữa các mô hình và trích xuất luật phòng thủ khả thi dưới góc độ Mạng máy tính.

CHƯƠNG 5: KẾT QUẢ VÀ THẢO LUẬN

5.1. Phương pháp phân tích

Để đảm bảo tính khoa học và có thể tái lập, việc phân loại 131 time-window không được thực hiện theo cảm tính mà theo một quy trình bốn bước có hệ thống, áp dụng nhất quán cho toàn bộ danh sách:

1. Đối chiếu nguồn gốc IP: kiểm tra từng IP trong danh sách có thuộc dải IP công khai, đã được xác nhận chính thức của các crawler liệu có hợp pháp hay không cụ thể là Googlebot (66.249.64.0/19) và Bingbot (157.55.39.0/24, 207.46.13.0/24, 40.77.167.0/24, 13.66.139.0/24, 13.66.144.0/24).
2. Phân tích ngữ nghĩa đường dẫn (Sample_URI): quét chuỗi URI để tìm các từ khóa đặc trưng cho hành vi dò quét (wp-login, wp-admin, phpmyadmin, .env, xmlrpc, robots.txt) hoặc cho tài nguyên tĩnh (static, image, các đuôi .png/.jpg/.css/.js).
3. Áp dụng bộ quy tắc quyết định trên tổ hợp ba chiều đặc trưng khối lượng truy cập (request_count), tỷ lệ lỗi phía client (error_4xx_rate) và kích thước payload trung bình (avg_payload_bytes) để gán mỗi time-window vào một trong năm nhóm nguyên nhân khả dĩ.
4. Định lượng kết quả: tổng hợp số lượng và tỷ lệ phần trăm của từng nhóm trên toàn bộ 131 time-window, làm cơ sở để đánh giá lại mức độ tin cậy của cảnh báo gốc ở mục 5.4.

Nhóm nguyên nhân	Điều kiện áp dụng (theo thứ tự ưu tiên)	Diễn giải căn cứ
1. Crawler đã xác định	IP thuộc dải Googlebot hoặc Bingbot đã công bố chính thức.	Có bằng chứng xác thực nguồn IP, độ tin cậy cao nhất.
2. Dò quét / thăm dò	$\text{error_4xx_rate} \geq 0,5$; hoặc $\text{error_4xx_rate} \geq 0,2$ kèm URI chứa từ khóa dò quét (wp-login, .env...) hoặc $\text{request_count} \leq 10$.	Tỷ lệ lỗi cao bất thường trên số lượng request nhỏ là dấu hiệu đặc trưng của dò quét thủ công/tự động.
3. Bất thường payload / lỗi ứng dụng	$\text{avg_payload_bytes} \geq 100.000$ byte và $\text{request_count} \leq 15$.	Payload lớn bất thường trong khi khối lượng request thấp không phù hợp mô hình flood/scan.
4. Tăng tải đột biến hợp lệ (flash crowd)	$\text{request_count} \geq 50$ và $\text{error_4xx_rate} < 0,05$ (kèm hoặc không kèm từ khóa tài nguyên tĩnh trong URI).	Khối lượng cao nhưng tỷ lệ thành công gần như tuyệt đối không có dấu hiệu bị từ chối truy cập.
5. Chưa phân loại rõ	Không thỏa điều kiện của bốn nhóm trên.	Cần chuyên gia rà soát thủ công từng trường hợp.

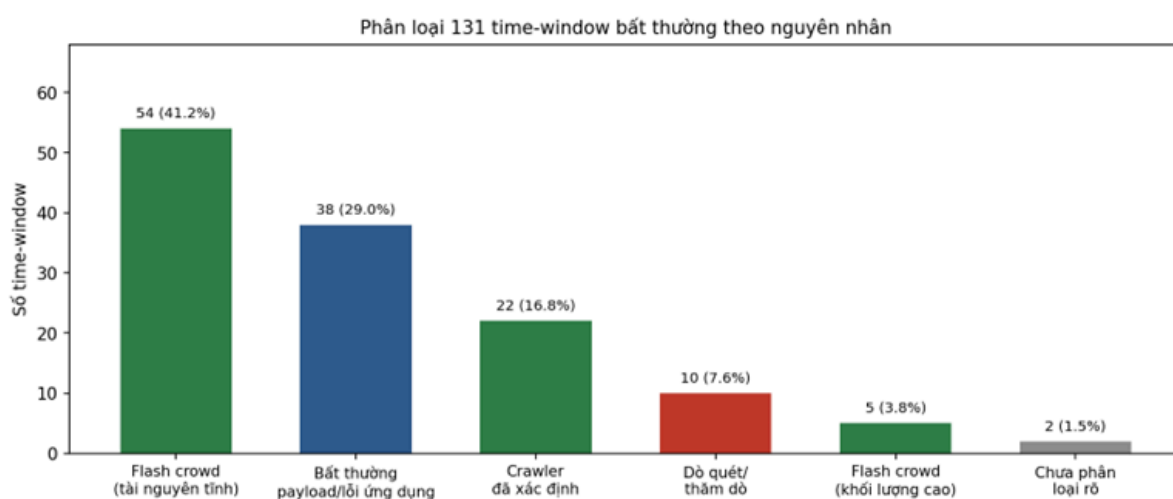
Bảng 5.1. Bộ quy tắc quyết định dùng để phân loại nguyên nhân bất thường

5.2. Kết quả phân loại định lượng

Kết quả phân bố theo từng nhóm nguyên nhân được biểu diễn như bảng sau

Nhóm nguyên nhân	Số lượng	Tỷ lệ	Số IP riêng biệt	Mức độ tin cậy cảnh báo
Tăng tải đột biến hợp lệ (tài nguyên tĩnh)	54	41,2%	41	Thấp (khả năng FP cao)
Bất thường payload / lỗi ứng dụng	38	29,0%	5	Trung bình (cần điều tra)
Crawler đã xác định (Googlebot/Bingbot)	22	16,8%	5	Rất thấp (FP gần chắc chắn)
Dò quét / thăm dò	10	7,6%	8	Cao (đáng chú ý)
Tăng tải đột biến hợp lệ (khối lượng cao)	5	3,8%	5	Thấp (khả năng FP cao)
Chưa phân loại rõ	2	1,5%	2	Cần rà soát thủ công

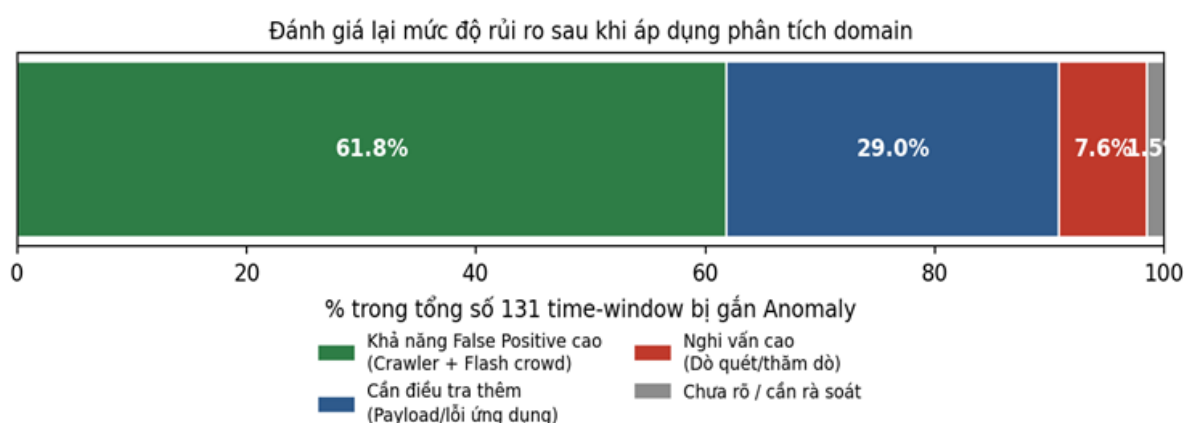
Bảng 5.2. Kết quả phân loại 131 time-window bất thường theo nguyên nhân



Hình 5.1. Phân bố số lượng time-window theo từng nhóm nguyên nhân

5.3. Đánh giá độ tin cậy của bất thường

Gộp năm nhóm nguyên nhân theo ba mức độ rủi ro thực tế cho phép nhìn lại toàn bộ danh sách 131 cảnh báo dưới góc độ vận hành ở mức “khả năng False Positive” cao gồm hai nhóm Crawler và Flash crowd; mức “cần điều tra thêm” gồm nhóm Bất thường payload; và mức “nghi vấn cao” là nhóm Dò quét/thăm dò.



Hình 5.2. Phân bố lại mức độ rủi ro của 131 cảnh báo sau khi áp dụng phân tích domain

Kết quả cho thấy một khoảng cách đáng kể giữa cảnh báo thô của mô hình và mức độ rủi ro thực tế: 61,8% (81/131) time-window nhiều khả năng là báo động giả do crawler hợp pháp hoặc tăng tải tự nhiên; chỉ 7,6% (10/131) thuộc nhóm thực sự đáng lo ngại về mặt an ninh. Nói cách khác, nếu xem toàn bộ 131 cảnh báo của Unsupervised là tín hiệu cần xử lý ngay, đội vận hành sẽ tốn phần lớn thời gian xử lý các trường hợp không mang lại giá trị an ninh thực sự.

5.4. Phân tích False Positive

5.4.1. Tiêu chí xác định False Positive

Vì dữ liệu gốc không có nhãn Anomaly/Normal được xác nhận độc lập, không thể tính Precision/Recall theo phương pháp thống kê chuẩn. Do đó, theo “*Outside the closed world: On using machine learning for network*

intrusion detection (2010)”, một time-window được xác định là False Positive khi có sự hội tụ của cả ba bằng chứng độc lập sau đây, thay vì dựa trên một ngưỡng số đơn lẻ:

- Nguồn gốc IP đã xác thực: IP thuộc dải công khai, được Google/Microsoft chính thức công bố là crawler hợp pháp.
- Ngữ nghĩa URI phù hợp với truy cập hợp lệ: đường dẫn là tài nguyên tĩnh (ảnh, CSS, JS) hoặc trang thông thường, không chứa dấu hiệu dò quét hay khai thác.
- Tỷ lệ lỗi 4xx gần 0: request được server xử lý thành công, không có dấu hiệu bị từ chối truy cập hàng loạt.

Chỉ khi cả ba điều kiện cùng thỏa mãn, time-window mới được xếp vào nhóm False Positive với độ tin cậy cao; nếu chỉ thỏa một hoặc hai điều kiện, trường hợp đó được giữ ở mức “cần điều tra thêm” thay vì loại bỏ hoàn toàn (xem nhóm Bất thường payload ở Mục 5.6).

5.4.2. Các nhóm được xác định là False Positive

Nhóm	Số lượng	Bằng chứng loại trừ tấn công	Vì sao mô hình vẫn gắn nhãn Anomaly
Crawler đã xác định (Googlebot/Bingbot)	22 (16,8%)	IP nằm trong dải IP đã công bố chính thức của Google/Microsoft; hành vi crawl có tính hệ thống, lặp lại theo chu kỳ.	request_count và error_4xx_rate cao hơn hẳn traffic người dùng thông thường do bot quét toàn bộ site kể cả các link đã hỏng.
Tăng tải đột biến hợp lệ (tài nguyên tĩnh)	54 (41,2%)	error_4xx_rate ≈ 0 (gần như mọi request đều thành công); toàn bộ Sample URI là	request_count và unique_uri_count vượt ngưỡng thống kê chung do nhiều người dùng thật

		ảnh/CSS/JS; nhiều IP nguồn khác nhau cùng truy cập.	cùng tải chung một nhóm tài nguyên trong cùng 1 phút.
Tăng tải đột biến hợp lệ (khối lượng cao khác)	5 (3,8%)	error_4xx_rate thấp, không có mẫu hình lỗi hệ thống hay dò quét kèm theo.	Cùng cơ chế với nhóm trên nhưng không giới hạn ở tài nguyên tĩnh vẫn là khối lượng cao nhưng không kèm dấu hiệu bị từ chối truy cập.

Bảng 5.3. Chi tiết các nhóm được xác định là False Positive (tổng 81/131, 61,8%)

5.4.3. Nguyên nhân gốc rễ

Isolation Forest chỉ quan sát bảy đặc trưng số, trong đó bốn đặc trưng (request_count, unique_uri_count, avg_payload_bytes, max_payload_bytes) đều thuộc nhóm khối lượng (volume-based) và không mang thông tin về loại nội dung hay mức độ tin cậy của nguồn truy cập. Hệ quả là bất kỳ traffic nào có khối lượng cao trong không gian đặc trưng này đều bị mô hình xem là cùng một loại Anomaly bất kể đó là một cuộc tấn công HTTP flood, một đợt crawl hợp pháp. Đây là hạn chế cố hữu của cách tiếp cận thuần thống kê không giám sát: mô hình phát hiện được khác biệt nhưng không phân biệt được vì sao khác biệt và không thể khắc phục chỉ bằng cách điều chỉnh tham số contamination, mà cần bổ sung tầng đặc trưng hoặc tầng luật nghiệp vụ như trình bày ở Mục 5.4.4.

5.4.4. Đề xuất giảm thiểu False Positive

Whitelist nguồn tin cậy ở tầng thu thập dữ liệu: loại các IP crawler đã xác thực (Googlebot, Bingbot...) ra khỏi tập huấn luyện/suy luận của mô hình ngay từ đầu, thay vì lọc thủ công sau khi có kết quả.

Bổ sung đặc trưng theo loại tài nguyên: tách traffic tài nguyên tĩnh (ảnh, CSS, JS) thành một nhóm có ngưỡng thống kê riêng, không dùng chung baseline với traffic đến trang động/API.

Chuẩn hóa ngưỡng theo ngữ cảnh thay vì theo toàn cục: request_count cao là bình thường với endpoint phục vụ ảnh sản phẩm nhưng bất thường với endpoint đăng nhập hay thanh toán mô hình hiện tại áp dụng chung một ngưỡng cho mọi loại URI.

Bổ sung tín hiệu định danh phiên (session/cookie) nếu hệ thống log có ghi nhận, để phân biệt “nhiều người dùng khác nhau cùng truy cập” (flash crowd hợp lệ) với “một nguồn duy nhất tạo nhiều request” (đặc trưng của bot/tấn công).

5.5. Phân tích sâu nhóm rủi ro cao: Dò quét/thăm dò

Đây là nhóm duy nhất có bằng chứng phù hợp với hành vi tấn công/trình sát mạng thực sự, với 10 time-window đến từ 8 IP riêng biệt (Bảng 5.2). Ba mẫu hình đáng chú ý được ghi nhận:

- Dò tìm điểm quản trị CMS: các IP 196.64.216.172 và 110.23.220.125 cùng truy vấn /wp-login.php một đường dẫn quản trị đặc trưng của WordPress. Việc hai IP độc lập cùng truy vấn một đường dẫn không thuộc kiến trúc site là một phần của chiến dịch quét hàng loạt nhiều website để tìm hệ quản trị nội dung phổ biến, không nhắm riêng vào hệ thống này.
- Dò quét tệp cấu hình/khai báo: IP 144.76.119.99 truy vấn /robots.txt với tỷ lệ lỗi cao bất thường có thể là bước khảo sát đầu tiên trước khi quét sâu hơn vào cấu trúc site.
- Truy vấn dồn dập một tài nguyên với tỷ lệ lỗi tuyệt đối: IP 31.184.130.52 tạo 27 request trong 1 phút tới /product/34423 với error_4xx_rate = 100% toàn bộ request đều thất bại, khác hẳn hành vi

duyet web thông thường của người dùng thật, gợi ý dò ID sản phẩm bằng script tự động (ID enumeration).

8 IP thuộc nhóm này nên được chuyển ngay cho vận hành/an ninh (SOC) để đối chiếu thêm với log ở các khung giờ khác và cân nhắc áp dụng biện pháp giám sát hoặc chặn tạm thời nếu tần suất dò quét tiếp diễn.

5.6. Phân tích nhóm chiếm tỷ trọng lớn: Bất thường payload/lỗi ứng dụng

Nhóm này chiếm 29,0% tổng số cảnh báo tỷ trọng lớn thứ hai (Bảng 5.2) nhưng bằng chứng không cho thấy dấu hiệu tấn công. Điểm chung của phần lớn các trường hợp trong nhóm là Sample_URI chứa chuỗi ký tự đã bị mã hóa phần trăm (percent-encoding) của bảng chữ cái Ba Tư/Ả Rập (ví dụ dạng %D8%..., %D9%...), xuất hiện trong đường dẫn sản phẩm như /product/32374/62714/... Đây là bằng chứng cho thấy hệ thống đang phục vụ người dùng nói tiếng Ba Tư (thị trường Iran/Trung Đông), và việc payload trung bình tăng vọt lên hàng trăm KB nhiều khả năng bắt nguồn từ cách máy chủ hoặc tầng ghi log xử lý chuỗi Unicode đa byte trong đường dẫn mỗi ký tự Ba Tư chiếm nhiều byte hơn ký tự ASCII thông thường, và nếu kèm theo lỗi 4xx (50% trong các trường hợp quan sát được), khả năng cao là trang lỗi trả về có kích thước lớn bất thường do lỗi cấu hình, không phải do bên ngoài chủ động gửi payload lớn để tấn công.

Nên chuyển nhóm này cho đội vận hành hệ thống để kiểm tra cấu hình xử lý encoding URL và log ghi nhận ký tự Unicode, đồng thời xác nhận lại với phần xử lý dữ liệu trước đó về cách dữ liệu gốc ghi nhận trường bytes cho các request có URI chứa ký tự ngoài ASCII.

5.7. Kết luận cho mô hình Isolation Forest

Tổng hợp lại, đi đến kết luận rằng mô hình Isolation Forest của Unsupervised hoạt động đúng chức năng của một bộ lọc thống kê tầng một

thu hẹp hiệu quả 100.000 request thô xuống còn 131 time-window đáng chú ý, nhưng bản thân con số 131 không nên được trình bày hoặc sử dụng như một danh sách sự cố an ninh đã xác nhận, do 61,8% trong số đó đã được xác định là False Positive ở Mục 4.4. Sau khi áp dụng lớp phân tích domain, nhóm khuyến nghị các hành động cụ thể sau:

1. Đưa 5 IP thuộc dải Googlebot/Bingbot đã xác định vào whitelist giám sát, loại khỏi vòng cảnh báo cho các chu kỳ phân tích tiếp theo.
2. Tách riêng một ngưỡng/luật cho traffic tài nguyên tĩnh (ảnh, CSS, JS) trong bước trích xuất đặc trưng, nhằm giảm tỷ lệ 41,2% time-window bị gắn nhãn sai do tăng tải đột biến hợp lệ.
3. Chuyển 8 IP thuộc nhóm Dò quét/thăm dò cho đội SOC để theo dõi mở rộng và cân nhắc chặn tạm thời.
4. Chuyển nhóm Bất thường payload cho đội phát triển kiểm tra lỗi encoding, không xử lý như sự cố an ninh.

5.8. Kết luận chương 5

Chương 5 đã hoàn thành việc kiểm định và diễn giải ngữ nghĩa cho 131 time-window bất thường bằng quy trình đánh giá domain 4 bước hệ thống. Kết quả định lượng bóc tách rõ khoảng cách giữa điểm số mô hình và rủi ro thực tế: 61,8% cảnh báo là báo động giả (False Positive) đến từ Crawler hợp lệ và hiện tượng tăng tải đột biến (Flash Crowd) do hạn chế thuần thống kê của mô hình; 29,0% bắt nguồn từ lỗi cấu hình ứng dụng và mã hóa Unicode (tiếng Ba Tư); và chỉ 7,6% (10 time-window thuộc 8 IP nguồn) thực sự là các hành vi dò quét điểm yếu nguy hiểm (*wp-login*, ID enumeration).

Kết quả này khẳng định Isolation Forest đóng vai trò xuất sắc như một bộ lọc thống kê tăng một giúp cô lập vùng nghi vấn từ 100.000 log thô. Trên cơ sở đó, nghiên cứu đề xuất 4 khuyến nghị vận hành thực tiễn: bổ sung

whitelist bot chính thức, tách ngưỡng giám sát cho tài nguyên tĩnh, chuyển 8 IP rủi ro cao cho đội SOC xử lý và chuyển nhóm lỗi encoding cho đội Dev/Ops tinh chỉnh hệ thống.

CHƯƠNG 6: KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN

Báo cáo đã xây dựng thành công một quy trình xử lý khép kín từ nhật ký thô tới kết quả phân tích có thể diễn giải, bao gồm các module Python độc lập, hoàn toàn tái lập được nhờ cố định hạt giống ngẫu nhiên. Quy trình đã chuyển đổi 100.000 dòng nhật ký thô thành hai bộ đặc trưng có cấu trúc ở cấp cửa sổ thời gian và cấp địa chỉ IP, trên đó huấn luyện mô hình Isolation Forest học không giám sát trên đặc trưng theo IP.

Về mặt kết quả định lượng, mô hình học máy không giám sát Isolation Forest thu hẹp 3.987 hồ sơ địa chỉ IP xuống còn một danh sách ngắn các tác nhân đáng chú ý, trong đó phát hiện được một dạng bất thường theo chiều dung lượng mà bộ luật thủ công hoàn toàn bỏ sót.

Trả lời câu hỏi nghiên cứu: các đặc trưng hành vi trích xuất từ log HTTP cho phép khoanh vùng bất thường tốt hơn ngưỡng đơn lẻ, nhưng "khoanh vùng được" và "là tấn công thật" là hai việc khác nhau - trong 131 cảnh báo gốc của Isolation Forest, chỉ 7,6% có bằng chứng phù hợp tấn công/trình sát thực sự, còn 61,8% nhiều khả năng false positive từ crawler hợp pháp hoặc tăng tải tự nhiên.

Hạn chế: mẫu chỉ phủ một buổi sáng của một ngày; độ chính xác thời gian giới hạn ở mức phút; hai thành viên giả định hai tỷ lệ bất thường cơ sở khác nhau chưa được đối chiếu bằng nguồn thứ ba. Bên cạnh đó, nhãn dùng để huấn luyện/đánh giá vẫn là nhãn yếu, chưa phải nhãn tấn công xác nhận độc lập bởi chuyên gia hoặc dữ liệu có nhãn thật do đó chưa có được sự kiểm chứng một cách chính xác nhất.

Hướng phát triển: báo cáo có thể được mở rộng quy mô và khoảng thời gian lấy mẫu qua đó xây dựng đường cơ sở có tính chu kỳ và để cho phép so sánh lưu lượng của một khung giờ với chính khung giờ đó ở các ngày trước thay vì mức trung bình toàn cục. Bên cạnh đó, để phát triển mô hình, ta cũng nên đối chiếu với một tập dữ liệu công khai có nhãn tấn công thật (ví dụ CSIC 2010 HTTP Dataset) để kiểm chứng độc lập độ chính xác toàn bộ pipeline

thay vì chỉ đo mức trùng khớp với bộ luật. Báo cáo cũng có thể được cải tiến bằng cách triển khai cơ chế xác thực crawler bằng tra cứu DNS ngược kết hợp tra cứu xuôi, thay cho việc so khớp dải địa chỉ vốn có thể bị giả mạo, để tự động loại nhóm bot hợp lệ khỏi vòng cảnh báo.

TÀI LIỆU THAM KHẢO

- [1]. Zaker, F. (2019). *Online Shopping Store - Web Server Logs* (V1) [Dataset]. Harvard Dataverse. <https://doi.org/10.7910/DVN/3QBYB5>
- [2]. Dabbas, E. (2020). *Web Server Access Logs* [Dataset]. Kaggle. <https://www.kaggle.com/datasets/eliasdabbas/web-server-access-logs>
- [3]. Ngô, H. A. (2026). *Mạng máy tính: Nguyên lý, giao thức, an toàn và phân tích dữ liệu mạng* (Giáo trình học phần COSH201). Trường Đại học Ngoại thương.
- [4]. Liu, F. T., Ting, K. M., & Zhou, Z.-H. (2008). Isolation forest. *2008 Eighth IEEE International Conference on Data Mining*, 413–422. <https://doi.org/10.1109/ICDM.2008.17>
- [5]. Scikit-learn developers. (n.d.). *sklearn.ensemble.IsolationForest*. Scikit-learn Documentation. Truy cập ngày 12/09/2026, từ <https://scikit-learn.org/stable/modules/generated/sklearn.ensemble.IsolationForest.html>
- [6]. Scikit-learn developers. (n.d.). *sklearn.tree.DecisionTreeClassifier*. Scikit-learn Documentation. Truy cập ngày 12/09/2026, từ <https://scikit-learn.org/stable/modules/generated/sklearn.tree.DecisionTreeClassifier.html>
- [7]. Field, R. (Ed.). (2022). *HTTP Semantics* (RFC 9110). Internet Engineering Task Force (IETF). <https://www.rfc-editor.org/rfc/rfc9110>
- [8]. OWASP Foundation. (2021). *OWASP Top 10 - A03:2021 Injection*. https://owasp.org/Top10/A03_2021-Injection/

- [9]. Kurose, J. F., & Ross, K. W. (2020). *Computer Networking: A Top-Down Approach* (8th ed.). Pearson.
- [10]. Sommer, R., & Paxson, V. (2010). Outside the closed world: On using machine learning for network intrusion detection. *2010 IEEE Symposium on Security and Privacy*, 305–316. <https://doi.org/10.1109/SP.2010.25>
- [11]. Kuhn, M., & Johnson, K. (2019). *Feature Engineering and Selection: A Practical Approach for Predictive Models*. CRC Press.
- [12]. Cloudflare. (n.d.). *HTTP flood (Layer 7 DDoS) attack*. Cloudflare Learning Center. Truy cập ngày 12/09/2026, từ <https://www.cloudflare.com/learning/ddos/http-flood-ddos-attack/>
- [13]. Greene, J., & Knott, M. (2017). *Web robot detection in academic publishing*. arXiv. <https://arxiv.org/abs/1711.05098>